



*Asociación Profesional de Cuerpos Superiores
de Sistemas y Tecnologías de la Información
de las Administraciones Públicas.*

Temas Generales para la preparación de la Oposición al Cuerpo
Superior de Sistemas y Tecnologías de la Información de la
Administración del Estado.

TEMAS GENERALES IV: Dirección Pública

Tema 27. La política de protección de datos de carácter personal. Régimen jurídico. El Reglamento UE 2016/679, de 27 de abril, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos. Principios y derechos. Obligaciones. El Delegado de Protección de Datos en las Administraciones Públicas. La Agencia Española de Protección de Datos.

AUTOR: Miguel Rodríguez Martos.

Actualización 2019

ÍNDICE

1	5
2	8
2.1	8
2.2	8
2.3	9
2.4	11
2.5	13
3	14
3.1	14
3.2	15
3.2.1	15
3.2.2	15
3.2.3	16
3.3	17
3.3.1	17
3.3.2	17
3.4	18
3.4.1	18
3.4.2	19
3.4.2.1.	20
3.4.2.2.	21
3.4.2.3.	21
3.4.2.4.	21
3.4.2.5.	22
3.4.2.6.	22
3.4.2.7.	22
3.4.2.8.	23
3.4.2.9.	23
3.4.2.10.	23
3.4.3	24
3.5	24
3.5.1	26
3.5.2	26
3.5.3	26
3.5.4	27
3.5.5	28
3.5.6	28
3.5.7	29
3.5.8	29
3.5.9	30
3.5.9.1.	30
3.5.9.2.	31
3.6	31
3.7	32
3.7.1	32

3.7.2	33
3.7.3	33
3.7.3.1.	33
3.8	33
3.8.1	34
3.8.2	34
3.8.2.1.	34
3.9	35
4	37
4.1	37
4.2	37
4.3	37
5	39
5.1	39
5.2	39
5.2.1	40
5.2.2	40
5.2.3	40
5.2.4	41
5.2.5	41
5.2.6	41
5.2.7	41
5.2.8	42
5.2.9	42
5.2.10	42
5.2.11	43
5.3	43
5.3.1	43
5.3.2	43
5.3.2.1.	43
5.3.2.2.	44
5.3.3	44
5.3.4	44
5.3.5	44
5.3.6	44
5.3.7	44
5.3.8	45
5.3.9	45
5.4	45
5.5	45
5.6	45
5.7	46
5.8	46
5.9	46
5.9.1	47
5.9.2	47
5.9.3	48

5.9.4	48
5.10	48
5.11	49
6	51
6.1	51
6.2	51
6.3	52
6.4	52
6.5	52
6.6	53
7	55
7.1	55
7.2	55
7.3	55
7.4	56
7.5	56
7.6	57
7.7	58
7.8	58
7.9	58
7.10	58
8	59
9	62
10	63
10.1	63
10.2	68
11	69
11.1	69
11.2	69

1 Introducción

La protección de las personas físicas en relación con el tratamiento de sus datos personales está sufriendo una evolución a todos los niveles. Una evolución que está siendo liderada por Europa, por razones históricas y culturales, y que se antoja imprescindible, por la rápida evolución tecnológica experimentada en la última década, que está multiplicando tanto la cantidad de datos disponibles como las posibilidades de explotación de estos.

Los ciudadanos, en el mundo hiperconectado en el que se desenvuelven hoy día, facilitan datos personales de forma masiva, tanto de forma voluntaria y consciente, como puede ser al rellenar un formulario de alta en un servicio, como de forma prácticamente inconsciente, al usar su teléfono móvil o navegar por internet. Por otro lado, las organizaciones gestionan y explotan esos datos cada vez de forma más extendida.

¿Qué datos manejan de nosotros estas organizaciones? ¿Para qué los utilizan? ¿Qué decisiones se toman en base a esos datos? ¿Durante cuánto tiempo los conservan? ¿Se los ceden a terceros? ¿Tenemos el control de nuestros datos personales? ¿Podemos hacer algo para recuperarlos? Todas estas respuestas deben ponerse a nuestro alcance a través de una política de protección de datos personales clara y fácilmente comprensible. El ciudadano es el propietario de sus datos personales, y por tanto debe conocer de qué manera se van a tratar.

La preocupación entre los ciudadanos por el uso de sus datos personales ha ido aumentando a la par que se han ido sucediendo los escándalos por un uso inadecuado o por una protección insuficiente. Cambridge Analítica obtuvo ilegítimamente en 2014 los datos de 87 millones de usuarios de Facebook, datos que permitían hacer perfiles psicológicos y políticos, lo cual además no se hizo público hasta 2018, cuatro años después de haberse producido. También en 2018, se hizo público que Facebook estaba compartiendo los datos personales de sus usuarios con otras compañías como Amazon, Apple, Microsoft o Netflix, que en determinados casos podían llegar a conocer incluso el contenido de los mensajes privados entre los usuarios. Google por su parte ha anunciado que cierra su red social Google+ en 2019, después de dos incidentes diferentes que comprometieron los datos personales de 50 millones de usuarios. En otro incidente masivo, la hotelera Marriott ha admitido que sufrió un ataque por el que se filtraron datos personales de 500 millones de huéspedes de su cadena Starwood, incluyendo datos de contacto, así como datos bancarios y de tarjetas de crédito.

Estos son solo algunos ejemplos de una cascada de casos, en los que también se han visto envueltos empresas y organismos españoles, y que ha tenido un efecto sobre la percepción de la población española: la protección de datos es ya un asunto que preocupa mucho o bastante a tres de cada cuatro españoles, según el barómetro del CIS. Las reclamaciones ante la Agencia Española de Protección de Datos (AEPD) han crecido un 33%, superando las 13.000 al finalizar 2018.

Ante esta situación, la normativa europea ha evolucionado para asegurar un equilibrio entre el desarrollo tecnológico, el correcto tratamiento de los datos y su protección efectiva. En los siguientes capítulos, se desgranará el alcance de esta normativa: el Reglamento General de Protección de Datos, plenamente aplicable desde el 25 de mayo de 2018, los derechos que refuerza para el ciudadano, y las obligaciones que supone para los responsables y encargados del tratamiento, y en particular para las Administraciones Públicas. También se analizará la ley nacional de protección de datos que entró en vigor el 7 de diciembre de 2018, aprobada con un amplio consenso parlamentario, y que detalla y complementa la normativa europea.

El enfoque será siempre didáctico; no se pretende reproducir literalmente el contenido íntegro de la normativa, que por otra parte no es posible por su extensión, sino explicarla y acercarla al opositor, para que sea capaz de entender lo que pretende el legislador y aplicarlo con éxito tanto en un examen de conocimientos, como en una fase práctica (además de por supuesto en su carrera profesional).

Finalmente, una vez descubierto el marco jurídico, se presentará la figura del Delegado de Protección de Datos y su lugar en las Administraciones Públicas, y se analizará asimismo la organización y el papel de la autoridad de control nacional, la AEPD.

2 El derecho a la protección de datos

2.1 Introducción

El derecho a la protección de datos es un derecho fundamental, que deriva directamente del artículo 18.4 de la Constitución española. En dicho artículo, se establece que «la ley limitará el uso de la informática para garantizar el honor y la intimidad personal y familiar de los ciudadanos y el pleno ejercicio de sus derechos».

El Tribunal Constitucional se pronunció posteriormente y fue definiendo el alcance de este derecho en diversas sentencias. Por primera vez en la sentencia 254/1993, posteriormente en la 94/1998, o 292/2000, fue dotando a este derecho de un carácter autónomo e independiente del derecho a la intimidad. Así mientras el derecho a la intimidad persigue proteger frente a cualquier invasión en el ámbito personal y familiar, el derecho a la protección de datos persigue garantizar al sujeto «un poder de control sobre sus datos personales, sobre su uso y destino, con el propósito de impedir su tráfico ilícito y lesivo para la dignidad y derecho del afectado».

A nivel europeo, el Convenio 108 del Consejo de Europa de 1981 garantizó a cualquier persona física el derecho a la vida privada, con respecto al tratamiento automatizado de los datos de carácter personal correspondientes a dicha persona («protección de datos»).

En la actualidad, el derecho a la protección de datos de carácter personal está incluido en la Carta de Derechos Fundamentales de la Unión Europea proclamada en Niza en el año 2000. En su artículo 8, determina que toda persona goza de ese derecho en relación con los datos que la conciernan, y que quedará sujeto al control de una autoridad independiente. Está reflejando a su vez el contenido del artículo 16 del Tratado de Funcionamiento de la Unión Europea, que además determina que el Parlamento Europeo y el Consejo establecerán las normas para los organismos de la Unión y para los Estados Miembros en el ámbito de aplicación del Derecho Comunitario.

Es también importante observar que el derecho a la protección de datos personales no es un derecho absoluto, y que debe equilibrarse con otros derechos fundamentales, como puede ser la libertad de expresión y de información, que en ocasiones pueden primar sobre el derecho a la protección de datos.

En los siguientes apartados se analizarán las leyes más relevantes desarrolladas desde la Constitución, y el marco jurídico que rige a día de hoy.

2.2 Breve historia de su desarrollo normativo

El hecho de tener la consideración de derecho fundamental en nuestra Constitución, recordemos que dota a este derecho de una serie de garantías específicas, establecidas en la propia Constitución. En cuanto a su desarrollo normativo, debe hacerse mediante Ley y en este caso, como para el resto de los derechos incluidos en ese apartado 18, específicamente mediante Ley Orgánica, que requiere un especial consenso parlamentario.

Así, la primera ley que desarrolló ese artículo 18 es la Ley Orgánica 5/1992, de Regulación del Tratamiento Automatizado de los Datos de Carácter Personal (LORTAD). La LORTAD tardó siete años en disponer de su desarrollo reglamentario, que llegó con el Real Decreto 994/1999, Reglamento de Medidas de Seguridad de los Ficheros Automatizados que contengan Datos de Carácter Personal (RMS).

Pocos meses después de la aprobación de dicho reglamento se promulgó la Ley Orgánica 15/1999, de 13 de diciembre, de Protección de Datos de Carácter Personal (LOPD), que por primera vez parte de una Directiva europea que trata de armonizar la protección en todos los Estados Miembros, la Directiva

95/46/CE relativa a la Protección de las Personas Físicas en lo que respecta al Tratamiento de Datos Personales y a la libre circulación de estos datos. Esta nueva ley orgánica desarrolla la protección de datos más allá de los ficheros automatizados, incluyendo dentro de su ámbito de aplicación los datos de carácter personal registrados en soporte físico.

La LOPD también se mantuvo durante un largo período sin desarrollo reglamentario, hasta que en 2007 se promulgó el Real Decreto 1720/2007, por el que se aprobó el Reglamento de Desarrollo de la Ley Orgánica 15/1999, de Protección de Datos de Carácter Personal (RLOPD).

Este marco normativo se conservó hasta mayo de 2016, fecha en la que entró en vigor el Reglamento (UE) 2016/679 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos, (Reglamento General de Protección de Datos, RGPD) y por el que se deroga la Directiva 95/46/CE. O para ser más exactos, hasta el 25 de mayo de 2018, una vez finalizado el período de adaptación, y por tanto cuando comienza a ser aplicable dicho Reglamento.

Poco después, aún sin una ley nacional que adaptara la normativa española al nuevo Reglamento, se promulgó el Real Decreto 5/2018, de medidas urgentes para la adaptación del Derecho español a la normativa de la Unión Europea en materia de protección de datos. En este RD se regulaban determinadas cuestiones que no afectaban propiamente a la regulación del derecho a la protección de datos, por ser esto reserva de ley orgánica, si no al procedimiento administrativo, y que era urgente resolver, como los plazos de prescripción de las infracciones y sanciones, así como la designación de la AEPD como representante del Estado Español en el Comité Europeo de Protección de Datos. Su efecto se limitó hasta la fecha de aprobación de la nueva Ley Orgánica 3/2018, de Protección de Datos Personales y garantía de los derechos digitales (LOPDGDD), que entró finalmente en vigor el 7 de diciembre de 2018.

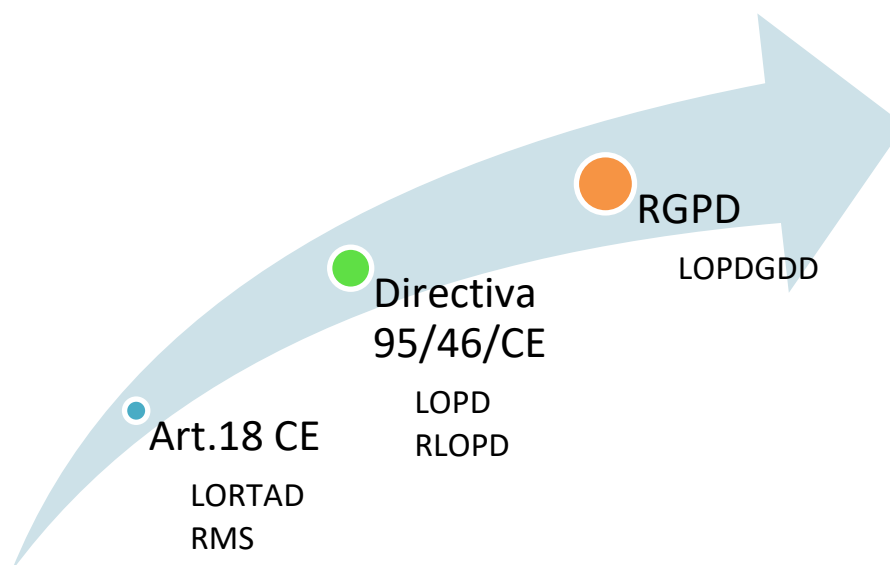


Figura 1 Evolución normativa de la protección de datos

2.3 Marco jurídico actual

El marco jurídico de la protección de datos en la actualidad está compuesto por las siguientes normas:

- 1) **El Reglamento (UE) 2016/679** relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos (**RGPD o el Reglamento**)
 - a) Entró en vigor el 24 de mayo de 2016, aunque no ha sido de plena aplicación hasta el 25 de mayo de 2018

- b) Al ser un Reglamento, es de aplicación directa en todos los Estados miembros y en el Espacio Económico Europeo sin necesidad de trasposición, y tiene primacía sobre las leyes nacionales
 - c) Deroga la Directiva 95/46/CE
- 2) **La Ley Orgánica 3/2018**, de Protección de Datos Personales y garantía de los derechos digitales (**LOPDGDD**)
- a) Entró en vigor el 7 de diciembre de 2018, al día siguiente de su publicación en el BOE
 - b) No contempla ningún período de adaptación
 - c) Deroga la Ley 15/1999 (antigua LOPD), sin perjuicio de lo previsto en la Disposición adicional decimocuarta de la LOPDGDD, relativa a las excepciones y limitaciones en el ejercicio de los derechos que hubiesen entrado en vigor con anterioridad a la fecha de aplicación del Reglamento.
 - d) Aunque el Real Decreto 1720/2007 de desarrollo de la LOPD de 1999 no ha sido derogado, y podría resultar de aplicación en lo que no contraviniera al RGPD ni a la LOPDGDD, la realidad es que no realiza ninguna aportación al marco jurídico por estar su articulado superado y renovado en su totalidad por el RGPD y la LOPDGDD
 - e) Aun siendo cierto que se espera un reglamento de desarrollo de la nueva LOPDGDD, la nueva ley ya concreta en gran medida los aspectos prácticos de la normativa, y en la misma solo se hace referencia en la disposición final decimoquinta a la posibilidad de desarrollar lo dispuesto en los artículos 3.2, 38.6, 45.2, 63.3, 96.3 y disposición adicional sexta. Se ha de tener en cuenta que de hecho ya es una ley que viene a completar un Reglamento europeo, a diferencia de las leyes anteriores, y por tanto su desarrollo será previsiblemente más reducido.
- 3) **La Directiva (UE) 2016/680**, relativa a la protección de las personas físicas en lo que respecta al tratamiento de datos personales por parte de las autoridades competentes para fines de prevención, investigación, detección o enjuiciamiento de infracciones penales o de ejecución de sanciones penales, y a la libre circulación de dichos datos (*Law Enforcement Directive*, **LED**)
- a) Entró en vigor el 6 de mayo de 2016, y su período de trasposición terminó el 6 de mayo de 2018, sin disponer aún en España de una ley nacional
 - b) Desarrolla el derecho a la protección de datos penales y fomenta la libre circulación en los ámbitos de la cooperación judicial en materia penal y de la cooperación policial, ámbitos excluidos del RGPD
 - c) No debe olvidarse que no se debe aplicar al tratamiento de datos personales en el marco de una actividad que no esté comprendida en el ámbito de aplicación del Derecho de la Unión, como la seguridad nacional
 - d) La autoridad de control para controlar las operaciones efectuadas por los órganos jurisdiccionales en el ejercicio de su función judicial es el Consejo General del Poder Judicial. En el resto de los casos, es la AEPD o las autoridades autonómicas en su ámbito territorial.
- 4) **Reglamento (UE) 2018/1725**, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales por las instituciones, órganos y organismos de la Unión, y a la libre circulación de esos datos
- a) Entró en vigor el 11 de diciembre de 2018
 - b) Es la normativa que aplica a los tratamientos realizados por las instituciones y los organismos de la Unión, excluidos del RGPD
 - c) La autoridad de control independiente en este ámbito es el Supervisor Europeo de Protección de Datos
- 5) **Ley 9/2014**, General de Telecomunicaciones (**LGT**)
- a) Específicamente en lo desarrollado en el artículo 48, a saber:
 - i) Derechos con respecto a las comunicaciones no solicitadas (llamadas automáticas y llamadas comerciales no deseadas)
 - ii) Limitación del tratamiento de datos de tráfico y datos de localización
 - iii) Derechos y obligaciones en relación con las guías de abonados

- b) La autoridad de control es la AEPD
- 6) **Ley 34/2002**, de servicios de la sociedad de la información y de comercio electrónico (**LSSI**)
- a) Específicamente en lo desarrollado en el artículo 21, prohibición de comunicaciones comerciales realizadas a través de correo electrónico o medios de comunicación electrónica equivalentes (envío de spam)
- b) La autoridad de control es la AEPD

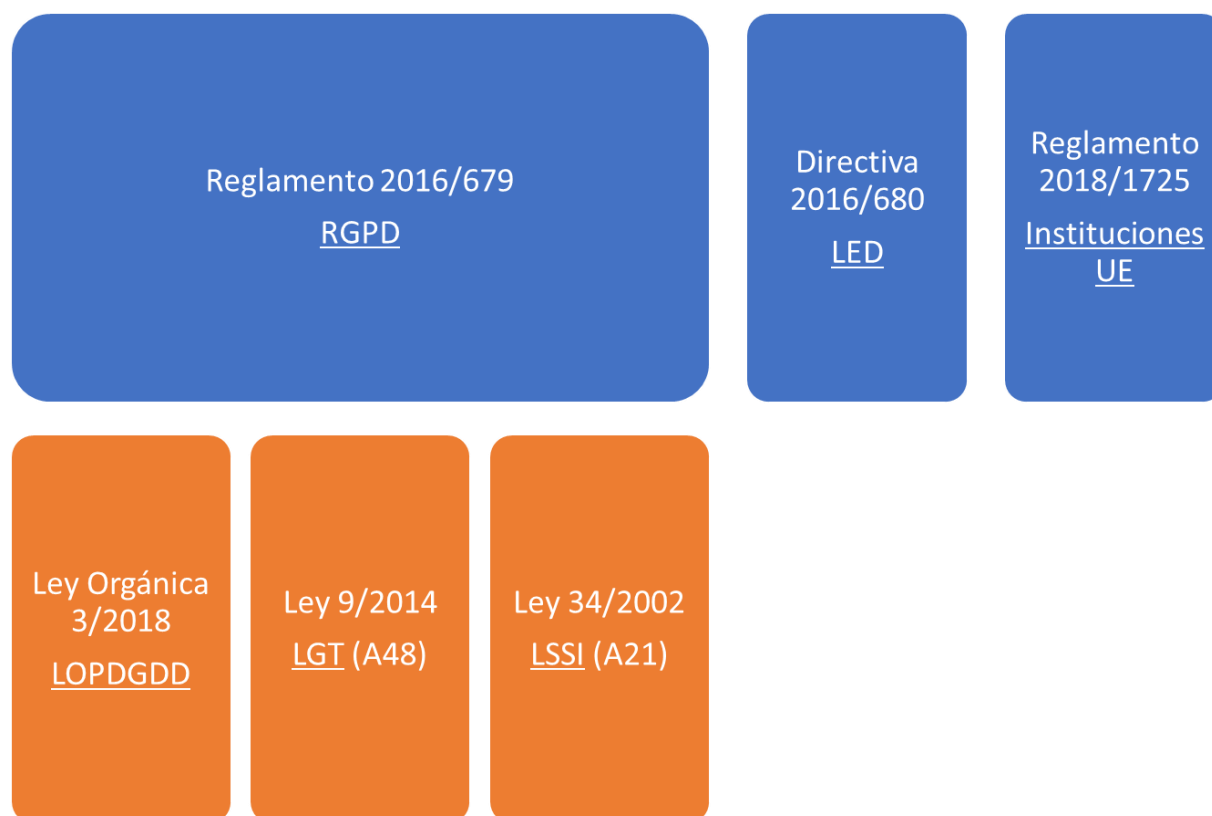


Figura 2 Marco jurídico

2.4 Conceptos básicos de la protección de datos

En este apartado se describen brevemente los conceptos fundamentales de la protección de datos, que será necesario conocer para comprender el resto del tema.

- **Dato personal:** toda información sobre una persona física identificada o identificable
 - o Una foto es un dato personal, como lo es una ubicación, o una nómina
 - o Una dirección IP también lo es, porque aporta información sobre una persona identificable
 - o Una información estadística anonimizada no lo es, siempre que los sujetos no sean identificables
- **Tratamiento:** cualquier operación realizada sobre los datos
 - o La mera recogida de datos ya se considera un tratamiento, aunque no se haga ninguna acción posterior sobre dichos datos
 - o El RGPD ya no habla de ficheros como en el marco anterior, si no de tratamientos
- **Responsable:** quien determina los fines y medios del tratamiento («controller» en la versión original del Reglamento)

- Es quien define y toma las decisiones sobre el tratamiento, aunque sea ejecutado por un encargado
 - Por ejemplo, un operador de telefonía móvil con respecto a los datos de sus clientes, o la Agencia Tributaria con respecto a los datos tributarios
- **Encargado:** quien trata los datos por cuenta del responsable («processor» en la versión original del Reglamento)
 - Un proveedor de IT que gestione el almacenamiento de los datos de un organismo será un encargado del tratamiento
- **Interesado:** el individuo a quien pertenecen los datos sobre los que se realiza el tratamiento («data subject» en la versión original del Reglamento)
- **Elaboración de perfiles:** cualquier forma de tratamiento de los datos personales que evalúe aspectos personales, en particular aspectos relacionados con el rendimiento en el trabajo, situación económica, salud, preferencias o intereses personales, fiabilidad o comportamiento
- **Seudonimización:** Es una garantía propuesta en el Reglamento y que consiste en realizar una disgregación sobre el tratamiento de datos personales de manera tal que ya no puedan atribuirse a un interesado sin utilizar información adicional
 - Dicha información adicional debe figurar por separado y estar sujeta a medidas técnicas y organizativas que impidan atribuir los datos a una persona
 - Un ejemplo deseudonimización consistiría en asignar y mostrar un código de cliente en sustitución del nombre completo para algunos tipos de tratamiento o usuarios de la aplicación, de manera que no puedan atribuir los datos que ven a una persona física si no lo necesitan para su operación

2.5 Conclusión

La normativa de referencia que regula de forma general el derecho a la protección de datos es el RGPD, así como la LOPDGDD de manera complementaria en nuestro país, y se estudiarán en detalle en los siguientes apartados.

Estas dos normas forman el núcleo central del régimen jurídico europeo y nacional. En el caso del resto de las leyes que conforman el marco jurídico presentado, cubren ámbitos muy específicos o sectoriales reducidos que no aplicarán en la generalidad de los organismos públicos o privados, y su estudio trasciende el objetivo de este tema y a sus epígrafes, siendo suficiente que el opositor conozca su existencia y sus claves fundamentales.

También es conveniente conocer que está en fase de tramitación el conocido como reglamento *ePrivacy*, relativo a la privacidad en las comunicaciones electrónicas. En todo caso, la propuesta de nuevo reglamento presentada por la Comisión se remite en todo lo relativo a protección de datos al RGPD, incluyendo el hecho de que prevé que las autoridades de control de la aplicación de este reglamento serán las mismas que supervisen la aplicación del RGPD.

3 El Reglamento General de Protección de Datos

3.1 Introducción

El RGPD remplacea al régimen de la Directiva 95/46/CE, transpuesta en España por medio de la antigua LOPD de 1999.

El Reglamento consta de 173 considerandos y 99 artículos, organizados en 11 capítulos. Los considerandos constituyen un elemento privilegiado para la interpretación de la normativa, y como tal han de entenderse.

El RGPD entró en vigor en 2016, si bien concedía un período de adaptación, por lo que no fue directamente aplicable hasta el 25 de mayo de 2018. Esta última es por tanto la fecha clave en que sus disposiciones comienzan a ser de obligado cumplimiento.

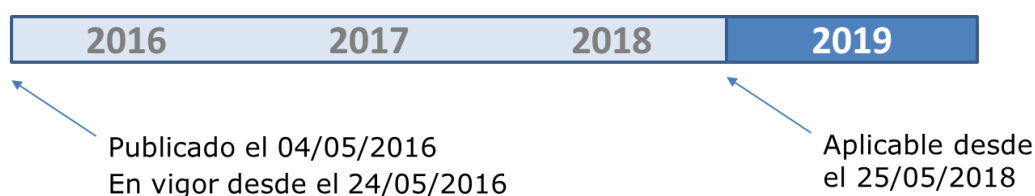


Figura 3 Fechas de aplicación del RGPD

Entre sus objetivos destacan dos frentes:

1. Adecúa la normativa a un mundo globalizado y en continua evolución tecnológica
2. Implica una mayor armonización

El primer objetivo no precisa mayor explicación para personas formadas en Tecnologías de la Información y las Comunicaciones (TIC): el aumento vertiginoso de la actividad online característica de la segunda década del siglo XXI, unido a tecnologías de explotación como el Big Data y la inteligencia artificial, habían dejado la antigua normativa claramente desfasada e insuficiente.

El segundo objetivo es menos intuitivo pues requiere trasladarse al escenario previo a la entrada en vigor del RGPD. El escenario en Europa mostraba una situación heterogénea, en la cual las normativas nacionales de los distintos Estados miembros divergían de forma notable en su manera de transponer los objetivos de la Directiva 95/46/CE. Así, por ejemplo, mientras en algunos Estados miembros, como España, la autoridad de control tiene potestades de investigación y sanción, en otros carece del poder de imponer sanciones económicas y, en algunos casos, sólo puede emitir recomendaciones o iniciar un proceso judicial si detecta una infracción de la normativa. Algo similar ocurre en otras materias desarrolladas, como los datos especialmente protegidos, las bases de legitimación del tratamiento, etc.

Sustituir esta fragmentación por la armonización que aporta el RGPD aporta toda una serie de ventajas:

- Favorece la libre circulación de datos personales en la Unión Europea (en adelante UE o Unión) con garantías
- Provee un igual nivel de protección en todos los Estados de la UE
- Contribuye al desarrollo de la economía digital en la UE
- Proporciona seguridad jurídica a los operadores continentales
- Elimina distorsiones a la libre competencia

El RGPD permite un desarrollo normativo nacional de forma limitada, e introduce mecanismos de cooperación y coherencia como se verá más adelante para su aplicación homogénea en todo el territorio europeo.

3.2 Ámbito

En esta sección se desarrolla el ámbito subjetivo, material y territorial regulado en los artículos 1, 2 y 3 del Reglamento. Esto es, en definitiva, dar respuesta a la pregunta de *¿a quién le afecta el Reglamento?*

3.2.1 Sujetos

En primer lugar, la normativa regula los tratamientos, realizados por personas, empresas u organizaciones, de datos personales de personas físicas. No aplica al tratamiento de datos de personas jurídicas. Por tanto, los datos que identifican a empresas u organizaciones no están protegidos por esta normativa. Sin embargo, los datos de personas que puedan tratar estas empresas y organizaciones sí están protegidos.

Por ejemplo, el domicilio social o la deuda de una empresa no son datos personales protegidos. Los nombre y apellidos de sus empleados, sí lo son.

No caben salvedades como las que recogía la antigua normativa nacional para los directorios de empleados y de empresarios individuales. Como datos de personas físicas que son, están incluidos en la normativa. No obstante, puede tener incidencia en la legitimación del tratamiento como se verá más adelante.

3.2.2 Materias

El Reglamento se aplica a todo tipo de tratamientos, sean automatizados o no.

No obstante, se excluyen expresamente del ámbito del RGPD:

- a) Las actividades no comprendidas en el Derecho de la UE
 - Se encuentran en esta situación, entre otros, los tratamientos realizados al amparo de la legislación orgánica del régimen electoral general, los tratamientos realizados en el ámbito de instituciones penitenciarias y los tratamientos derivados del Registro Civil, los Registros de la Propiedad y Mercantiles
- b) Los ámbitos de política exterior y seguridad común
- c) Las actividades personales o domésticas de personas físicas, que no guarden relación con ninguna actividad profesional o comercial
- d) Los tratamientos de infracciones y sanciones penales sometidos a la Directiva 2016/680, introducida al comienzo del tema
- e) Los tratamientos de instituciones y organismos de la UE, que tienen su propio Reglamento, introducido al comienzo del tema
- f) Los datos de personas fallecidas (el Considerando 27 da lugar a los Estados para regular este particular, lo cual hace la LOPDGDD)

Para aclarar la excepción c), podemos remitirnos al Considerando 18, que indica que este tipo de actividades incluyen la correspondencia y el mantenimiento de una agenda de direcciones, y la actividad en redes sociales o la actividad en línea en este contexto. Sin embargo, el Reglamento sí aplica a los responsables o encargados del tratamiento que proporcionen los medios (es decir, un ciudadano en su perfil *privado* no ha de preocuparse por ello, sin embargo, Facebook tiene que cumplir todas las obligaciones relacionadas y garantizar la seguridad y los derechos sobre los datos personales que está controlando).

3.2.3 Territorio

El Reglamento aplica directamente en los 28 países de la Unión Europea, y adicionalmente ha sido adoptado por los tres países del Espacio Económico Europeo que no forman parte de la Unión: Islandia, Noruega y Liechtenstein.

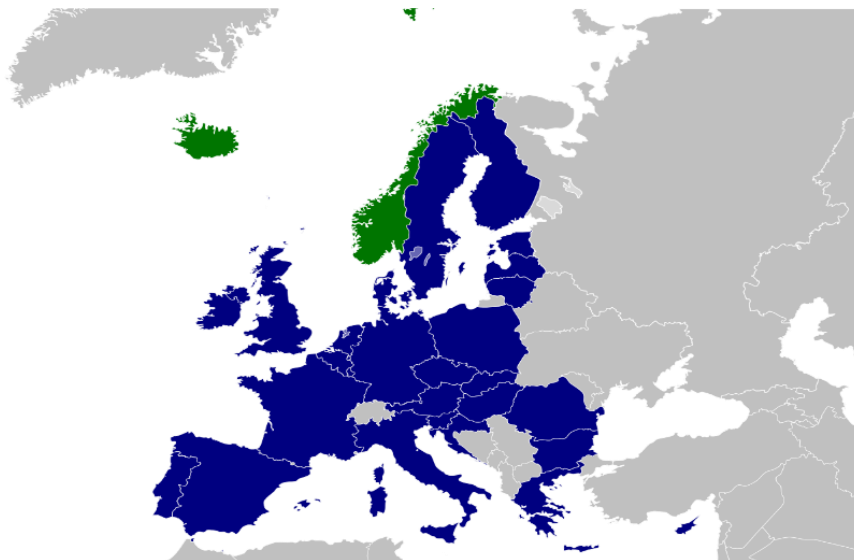


Figura 4 Mapa de aplicación del RGPD (EEE)

Si el Reino Unido abandona finalmente la UE, dejará de ser aplicable en su territorio. No obstante, el Reino Unido ya ha aprobado su propia legislación nacional alineada con el RGPD.

También aplica en todos aquellos lugares donde la normativa de los Estados miembros sea de aplicación en virtud del derecho público internacional (como embajadas en el exterior).

Es importante aclarar que lo que marca la ubicación y por tanto la aplicación del RGPD es el establecimiento del responsable o encargado donde se realizan las actividades relacionadas con el tratamiento. Por tanto, habrá que determinar en primer lugar dónde está establecido el responsable, en qué sede se efectúan las actividades por las cuales se realiza el tratamiento (con independencia de dónde se realice el tratamiento en sí).

Y el RGPD aún da un paso más para responder al reto creado por la globalización, y es que también se aplica el Reglamento al tratamiento de datos personales de ciudadanos que se encuentren en la UE incluso aunque el establecimiento del responsable no se encuentre en Europa, siempre que las actividades sean:

- Oferta de bienes y servicios a ciudadanos de la UE, incluso gratuitos
 - o Para determinar si se están ofreciendo bienes y servicios a ciudadanos europeos se atenderá a elementos como la lengua o la moneda utilizada (Considerando 23)
- El control del comportamiento de ciudadanos de la UE, si el comportamiento ocurre en la Unión

En este caso, el Reglamento no habla de residentes en la Unión, sino de ciudadanos que se *encuentren* en la Unión, es un matiz diferencial importante, porque aplicará a ciudadanos que se encuentren temporalmente en territorio europeo aun cuando no sean residentes.

Por tanto, el alcance es revolucionario. Cualquier empresa que ofrezca bienes o servicios a ciudadanos europeos, aunque no esté localizada en Europa, está obligada a cumplir el RGPD. Por ejemplo, el diario *The New York Times* tiene que hacerlo para con sus suscriptores o lectores online europeos. Lo mismo ocurre con empresas de seguimiento del comportamiento, como empresas de analítica web,

independientemente de dónde estén establecidas, siempre que se observe a individuos que se hallen en la Unión.

Los responsables o encargados no establecidos en la UE que ofrezcan bienes o servicios u observen comportamiento en la UE, tienen obligación de designar un representante en la Unión.

En el resto de los casos que no están dentro los dos escenarios anteriores, los responsables o encargados tendrán que cumplir el RGPD en tanto en cuanto el establecimiento que desarrolla las actividades esté en la Unión. Así, por ejemplo, una fábrica en Portugal que trate datos personales de sus proveedores estará dentro del alcance del Reglamento, aunque el tratamiento se haga en un servidor en Estados Unidos, porque se hace en el contexto de actividades del establecimiento en Portugal. En cambio, un fabricante establecido en China, que produzca materiales para empresas europeas, pero no venda a ciudadanos europeos, no estará sujeto al cumplimiento del Reglamento.

3.3 Licitud del tratamiento

En los días inmediatamente anteriores y posteriores al 25 de mayo de 2018, muchas compañías se lanzaron a buscar el consentimiento de sus clientes para el tratamiento de sus datos personales, enviando correos o comunicaciones justificadas en el RGPD, que realmente no siempre eran necesarias. Porque es cierto que el RGPD impone nuevas condiciones al consentimiento, pero también que incluye una serie de bases que legitiman los tratamientos de datos sin necesidad de obtener el consentimiento del interesado. El consentimiento no es la piedra angular para legitimar un tratamiento, constituye solo una base más cuando no hay otra que legitime el tratamiento.

3.3.1 Bases de legitimación

Para realizar un tratamiento de datos personales, hay que tener una base que lo legitime. El RGPD en su artículo 6 define cuáles son las posibles opciones que harían el tratamiento lícito:

- a) El consentimiento del interesado
- b) La ejecución de un contrato con el interesado
- c) El cumplimiento de una obligación legal del responsable
- d) La protección de intereses vitales
- e) El cumplimiento de una misión en interés público o en ejercicio de poderes públicos
- f) La satisfacción de intereses legítimos del responsable que puedan prevalecer (este supuesto no puede ser utilizado por las autoridades públicas en el ejercicio de sus funciones)

Cuando exista otra base legal para el tratamiento, no deberá recabarse el consentimiento.

En el caso particular de los datos tratados por las Administraciones Públicas, los tratamientos habitualmente se basarán en las condiciones c) o e), y por tanto deja de ser necesario obtener el consentimiento del interesado para realizar estos tratamientos, lo que supone un cambio de calado en los procedimientos administrativos. El Derecho de la Unión o de los Estados miembros debe ser el que otorgue esta obligación legal o misión que caracterizan estos dos escenarios.

3.3.2 El consentimiento

El consentimiento se define como una manifestación de voluntad por la que el interesado acepta el tratamiento de datos personales que le conciernen.

El consentimiento debe ser demostrable, por tanto, debe quedar registrado, y debe cumplir una serie de condicionantes para considerarse válido:

- Darse libremente

- Si la ejecución de un contrato o la prestación de un servicio se supedita al consentimiento del tratamiento de datos que no son necesarios para prestar el servicio, no se considerará que se ha dado libremente
- Si el interesado no puede denegar o retirar su consentimiento sin sufrir perjuicio alguno, no se considera libre
- Ser específico
- Darse habiendo sido informado de lo que supone hacerlo
- Ser inequívoco
- Solicitarse para cada uno de los fines de forma separada
- Debe ser tan fácil retirar el consentimiento como darlo

El consentimiento inequívoco en el RGPD es aquel que se ha realizado mediante una declaración o una clara acción *afirmativa*. Deja de ser válido el consentimiento tácito o por omisión. Esto es, ya no son válidas las casillas premarcadas, ni tomar la ausencia de respuesta o la inacción como un consentimiento. Debe realizarse una acción afirmativa. Activar una tarjeta de crédito o entrar en una página web después de haber sido informado, se consideran acciones afirmativas.

En ocasiones se ha entendido o publicado que el RGPD exige que el consentimiento sea *explícito*, pero esto no se ajusta a la realidad. Los ejemplos anteriores responden a consentimientos otorgados de forma implícita, pero conforme al RGPD al representar una acción afirmativa. Sólo es obligatorio el consentimiento explícito en el caso de las categorías especiales de datos que se verán más adelante.

Los tratamientos iniciados con anterioridad al inicio de la aplicación del RGPD sobre la base del consentimiento seguirán siendo legítimos siempre que ese consentimiento se hubiera prestado del modo en que prevé el propio RGPD, es decir, mediante una manifestación o acción afirmativa.

3.4 Mayor control para el interesado

En general, las personas están dispuestas a ofrecer sus datos personales a cambio de servicios, pero no saben qué datos ofrecen, ni para qué, ni por cuánto tiempo se van a utilizar y a guardar, ni cómo recuperar el control sobre su información. Sin embargo, los datos personales son del interesado, no de quien los gestiona, y el Reglamento viene a reforzar el control que puede ejercer el individuo sobre sus propios datos personales.

La propuesta incluye dos elementos fundamentales: principios más claros, y derechos reforzados. Además, establece una serie de categorías especiales de datos que no pueden ser objeto de tratamiento salvo excepciones (Artículo 9).

3.4.1 Principios

Los principios son los que rigen y basan todo el articulado posterior. Conociendo los principios y aplicando algo de sentido común, se pueden desarrollar procedimientos de actuación conformes con la normativa, o, al contrario, detectar infracciones en las actividades actuales.

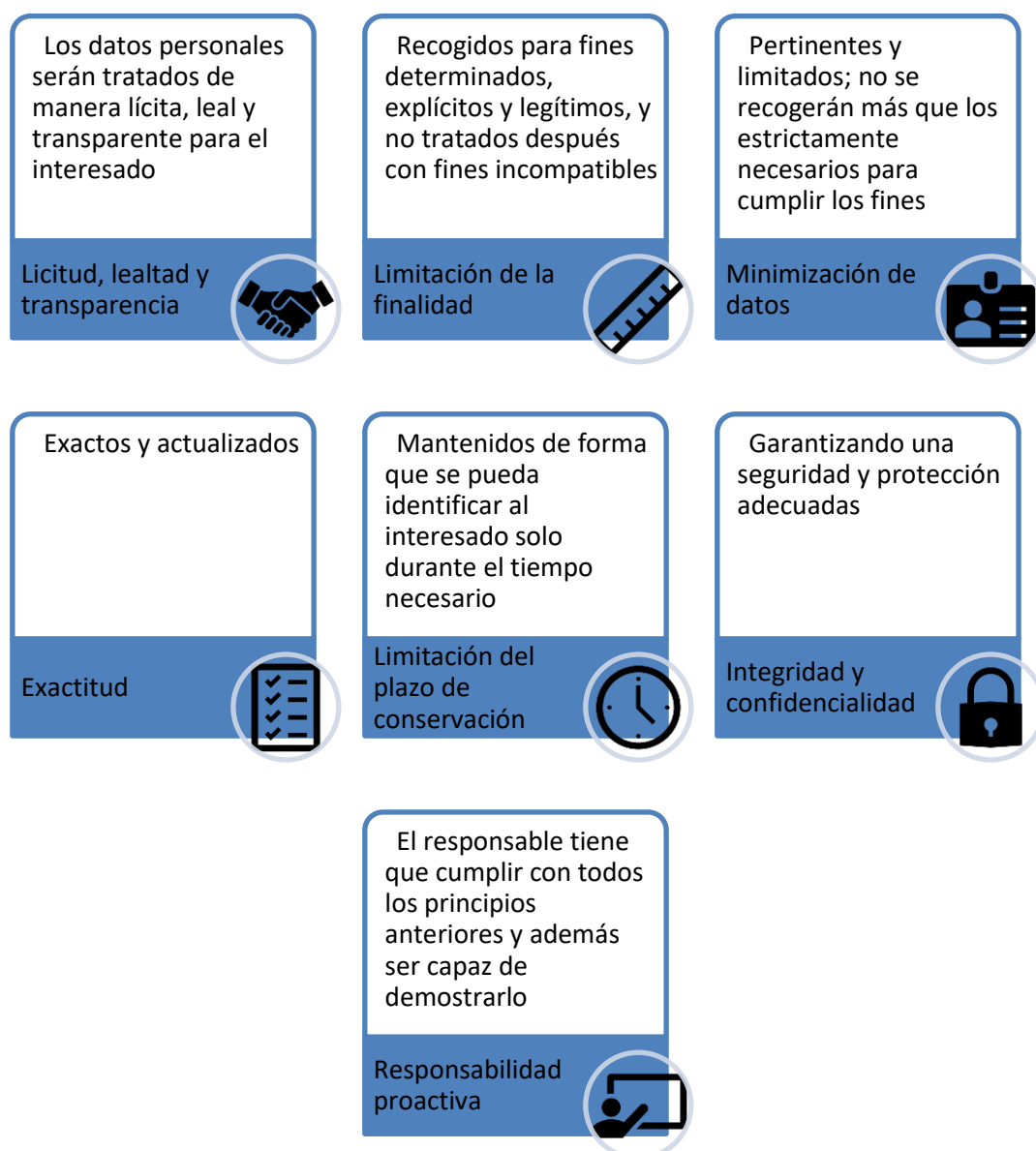


Figura 5 Principios relativos al tratamiento

Con respecto a la figura previa, se debe puntualizar que, de conformidad con el artículo 89.1, cuando se traten los datos con fines de archivo en interés público, fines de investigación científica e histórica o fines estadísticos:

- Con respecto a la limitación de la finalidad, no se consideran fines incompatibles con los iniciales
- Con respecto a la limitación del plazo de conservación, los datos personales podrán conservarse durante períodos más largos

3.4.2 Derechos

El RGPD reconoce una serie de derechos ampliados y reforzados con respecto a la cuádrupla de derechos ARCO (Acceso, Rectificación, Cancelación, Oposición) existente en la normativa derogada. De esta manera, se desarrolla el principio de transparencia o derecho a la Información, así como el derecho de Supresión (antes llamado de cancelación) que incluye el derecho al olvido, y se crean nuevos derechos: Limitación del tratamiento, Portabilidad de los datos y no ser objeto de Decisiones individuales automatizadas.

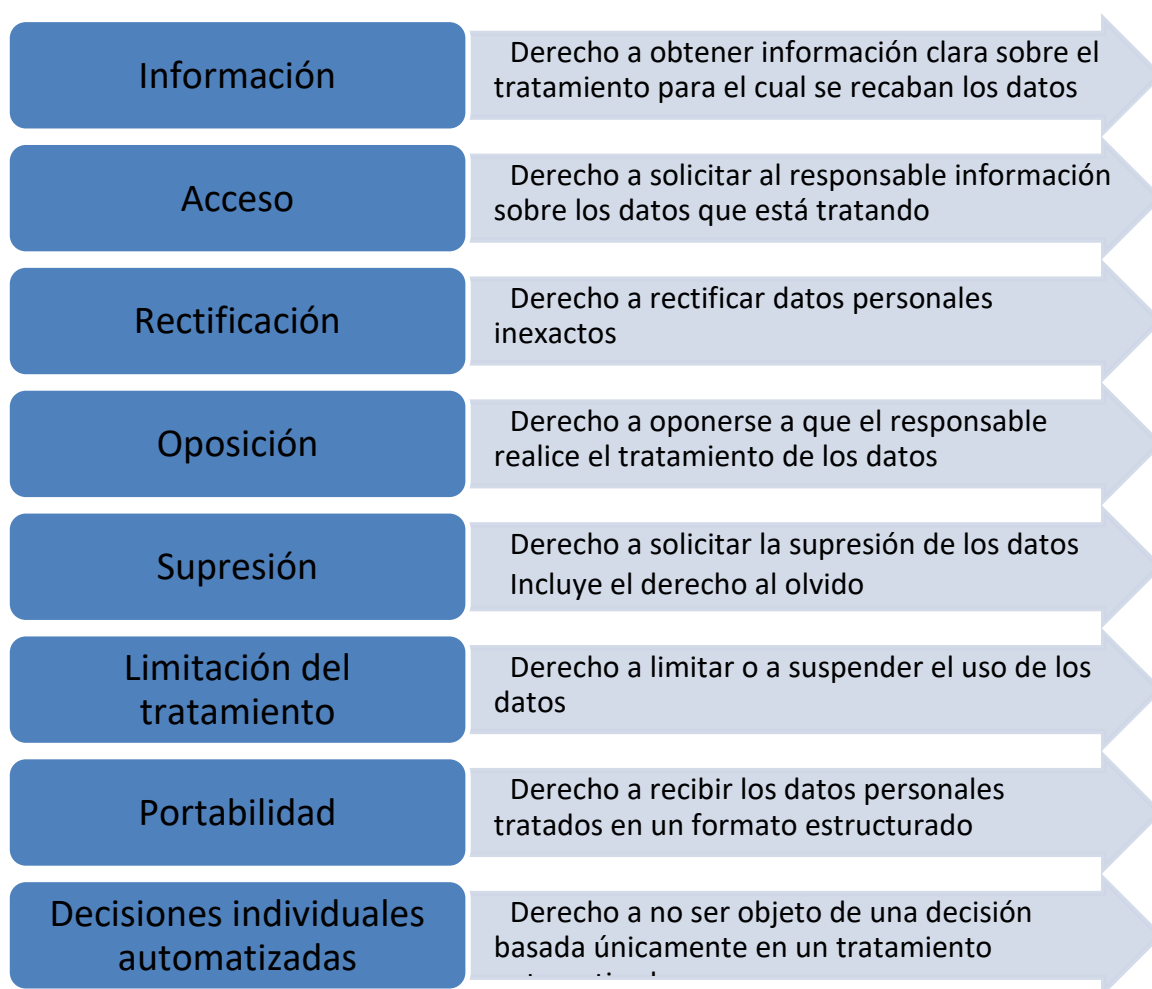


Figura 6 Derechos del interesado

En busca de un acrónimo para no olvidar ninguno de estos 8 derechos básicos del interesado, se puede optar por PILDORAS (Portabilidad, Información, Limitación, Decisiones, Oposición, Rectificación, Acceso, Supresión), aunque no los liste en un orden cronológico habitual del ejercicio de estos derechos.

3.4.2.1. Derecho de información

En función del origen de los datos, el Reglamento contempla dos escenarios en relación con la obligación de informar al interesado:

1. Cuando los datos los proporcione directamente el interesado: en este supuesto se informará en el momento de la recogida de datos
2. Cuando los datos procedan de otras fuentes: en este caso se proporcionará la información a más tardar en el plazo de un mes, salvo que:
 - a. Se utilicen para comunicarse con el interesado, en cuyo caso se le informará en la primera comunicación
 - b. Se comuniquen a un tercero, en cuyo caso se hará la primera vez que se comuniquen

Si el interesado ya dispone de la información, se eximirá al responsable de la obligación.

Además, también se exime de esa responsabilidad cuando no se recojan los datos del interesado, y se cumpla alguna de las siguientes premisas:

- La comunicación resulte imposible o suponga un esfuerzo desproporcionado

- En este caso, el responsable deberá adoptar medidas adecuadas para proteger los derechos, libertades e intereses del interesado, inclusive haciendo pública la información
- La obtención de datos esté determinada en alguna norma
- Los datos deban seguir siendo confidenciales sobre la base de una obligación de secreto profesional

La información que se debe proporcionar está explicitada también en el Reglamento, e incluye:

- Identidad del responsable
- Contacto del DPD, en su caso
- Fines del tratamiento, incluyendo la elaboración o no de perfiles
- Base jurídica del tratamiento, en los casos de obligación legal, interés público o interés legítimo
- Destinatarios de cesiones de los datos
- Transferencias de datos a terceros países
- Información sobre el ejercicio de derechos
 - Derechos del interesado
 - Derecho a retirar el consentimiento prestado
 - Derecho a reclamar ante una Autoridad de Control
- Plazo de conservación de los datos
- Obligación o no de facilitar datos y consecuencias de no hacerlo
- Existencia de decisiones individuales automatizadas

Si los datos no se recogieron del interesado, además se debe informar de la procedencia de los datos (aunque sea de fuentes de acceso público) y la categoría de los datos que se tratan.

3.4.2.2. Derecho de acceso

El interesado puede dirigirse al responsable en todo momento para conocer si se están tratando datos sobre él, y si es así, obtener información relacionada con el tratamiento (similar a la proporcionada durante la recogida) y, además, a obtener una copia de los datos objeto del tratamiento. Si se solicita por medios electrónicos, debe proporcionarse esa copia en un formato electrónico de uso común.

El ejercicio de este derecho será gratuito. Ahora bien, si las solicitudes son manifiestamente infundadas o excesivas, especialmente debido a su carácter repetitivo, el responsable del tratamiento podrá:

- Cobrar un canon razonable en función de los costes administrativos afrontados para facilitar la información o comunicación o realizar la actuación solicitada, o
- Negarse a actuar respecto de la solicitud

3.4.2.3. Derecho de rectificación

El interesado podrá rectificar o completar los datos inexactos o incompletos que le conciernen.

3.4.2.4. Derecho de oposición

El interesado puede oponerse a que sus datos personales sean objeto de un tratamiento que estuviera basado en:

- Una misión de interés público
- En el interés legítimo
- O tenga por objeto fines de mercadotecnia

Incluida la elaboración de perfiles relacionados.

En los dos primeros casos, el responsable podrá denegarlo alegando motivos imperiosos que prevalezcan.

3.4.2.5. Derecho de supresión («el derecho al olvido»)

El interesado puede solicitar la supresión de sus datos personales en las siguientes circunstancias:

- Si los datos ya no son necesarios para los fines para los que fueron recogidos
- Si se basaban en el consentimiento, y el interesado lo retira
- Si se ha ejercido el derecho de oposición en los supuestos enumerados en el apartado anterior
- Si los datos han sido tratados ilícitamente
- Si deben suprimirse para el cumplimiento de una obligación legal
- Si los datos se han obtenido para una oferta de servicios de la sociedad de la información a menores

Además, el RGPD une el derecho de supresión y lo extiende para incluir expresamente el derecho al olvido: el responsable del tratamiento que haya hecho públicos datos personales está obligado a indicar a los responsables que estén tratando tales datos personales que supriman todo enlace a ellos, o las copias o réplicas de tales datos. Esto afecta principalmente al caso de los buscadores como Google, que deben retirar los enlaces de los resultados de su buscador.

No obstante, el derecho de supresión tiene límites, de tal forma que puede ser factible no proceder a la supresión cuando el tratamiento sea necesario para el ejercicio de la libertad de expresión e información, para el cumplimiento de una obligación legal, para el cumplimiento de una misión realizada en interés público o en el ejercicio de poderes públicos conferidos al responsable, por razones de interés público, en el ámbito de la salud pública, con fines de archivo de interés público, fines de investigación científica o histórica o fines estadísticos, o para la formulación, el ejercicio o la defensa de reclamaciones.

Cuando la supresión derive del ejercicio del derecho de oposición con arreglo al artículo 21.2 del RGPD, el responsable podrá conservar los datos identificativos del afectado necesarios con el fin de impedir tratamientos futuros para fines de mercadotecnia directa.

3.4.2.6. Derecho a la limitación del tratamiento

La limitación del tratamiento supone que el responsable conserva los datos, pero sólo puede tratarlos con el consentimiento del interesado, o para la gestión de reclamaciones, o para la protección de los derechos de terceras personas, o por razones de interés público de la Unión o un Estado Miembro.

El interesado tiene derecho a solicitar la limitación cuando:

- Impugne la exactitud de los datos personales, durante un plazo que permita al responsable verificar la exactitud de estos
- El tratamiento sea ilícito y el interesado se oponga a la supresión de los datos personales y solicite en su lugar la limitación
- El responsable ya no necesite los datos, pero el interesado los necesite para realizar una reclamación
- El interesado se haya opuesto al tratamiento, mientras se verifica si los motivos legítimos del responsable prevalecen sobre los del interesado

3.4.2.7. Derecho a la portabilidad

Cuando el tratamiento se efectúe por medios automatizados, el interesado podrá recibir sus datos personales en un formato estructurado, de uso común, de lectura mecánica e interoperable, y transmitirlos a otro responsable del tratamiento, siempre que el tratamiento se legitime en base al consentimiento o en el marco de la ejecución de un contrato.

Por su propia naturaleza, no se podrá requerir cuando el tratamiento sea necesario para el cumplimiento de una misión de interés público o en el ejercicio de poderes públicos conferidos al responsable.

3.4.2.8. Derecho a no ser objeto de decisiones individuales automatizadas

El interesado tiene derecho a no ser objeto de una decisión basada únicamente en el tratamiento de sus datos, incluida la elaboración de perfiles, que produzca efectos jurídicos sobre él o le afecte significativamente de forma similar.

Este derecho también tiene sus limitaciones, y no será aplicable cuando:

- Sea necesario para la celebración o ejecución de un contrato
- El tratamiento se base en el consentimiento explícito del interesado
- El tratamiento esté autorizado por el Derecho de la Unión o de los Estados miembros

En los dos primeros casos, el responsable debe garantizar el derecho a obtener la intervención humana, expresar objeciones e impugnar la decisión.

3.4.2.9. Disposiciones comunes

En todo caso, el ejercicio de cualquiera de los derechos debe cumplir una serie de elementos:

- El responsable debe proveer la información de forma concisa, transparente, inteligible y de fácil acceso
- Por escrito o por otros medios, inclusive medios electrónicos
- Su ejercicio es gratuito
- Si las solicitudes son manifiestamente infundadas o excesivas el responsable podrá:
 - o Cobrar un canon proporcional a los costes administrativos soportados
 - o Negarse a actuar
- Las solicitudes deben responderse en el plazo de un mes, aunque, por razones de complejidad y número de solicitudes, se podrá prorrogar el plazo otros dos meses adicionales
- Si el responsable no da curso a la solicitud, informará, a más tardar en un mes, de las razones de su no actuación y de la posibilidad de reclamar ante una Autoridad de Control
- El responsable puede solicitar información adicional para identificar al interesado, siempre que haya dudas razonables sobre su identidad
 - o Esto no quiere decir que pueda solicitar de forma habitual una copia del DNI, debe hacer un ejercicio de proporcionalidad y justificar esas dudas sobre la identidad del interesado
- Si la solicitud se realiza por medios electrónicos, la información se facilitará por estos medios cuando sea posible, salvo que el interesado solicite que sea de otro modo

Si los fines para los cuales un responsable trata datos personales no requieren o ya no requieren la identificación del interesado por el responsable, este no estará obligado a mantener información adicional con el único objetivo de identificar al interesado para facilitarle el ejercicio de sus derechos o cumplir otras obligaciones del Reglamento.

3.4.2.10. Limitaciones

El RGPD en su artículo 23 da lugar a los Estados a limitar el ejercicio de derechos cuando sea necesario para salvaguardar:

- La seguridad del Estado
- La defensa
- La seguridad pública
- La investigación o enjuiciamiento de infracciones penales y ejecución de sanciones penales
- Otros objetivos importantes de interés público general

- Protección de la independencia judicial
- En la investigación o enjuiciamiento de infracciones de normas deontológicas
- En el ejercicio de la autoridad pública vinculada a los casos anteriores
- La protección del interesado
- La ejecución de demandas civiles

Esta limitación ha de formularse por medio de una medida legislativa.

3.4.3 Categorías especiales de datos

El Reglamento prohíbe el tratamiento de categorías especiales de datos personales, considerándose como tal: datos que revelen el origen étnico o racial, las opiniones políticas, las convicciones religiosas o filosóficas, o la afiliación sindical, y el tratamiento de datos genéticos, datos biométricos dirigidos a identificar de manera unívoca a una persona física, datos relativos a la salud o datos relativos a la vida sexual o la orientación sexual de una persona física. Con respecto a la normativa anterior, el Reglamento añade por tanto nuevas categorías de datos especialmente protegidos, como son los datos biométricos y los datos genéticos.

Naturalmente hay casos en que es ineludible tratar tales categorías de datos, por eso el Reglamento incluye una serie de excepciones:

- Cuando el interesado dé su consentimiento *explícito*, es decir, no podría ser un consentimiento basado en una acción afirmativa, sino que expresamente tendría que aceptar que se trataran este tipo de datos
- El tratamiento sea necesario para cumplir obligaciones y derechos específicos en el ámbito del Derecho laboral y de la seguridad y la protección social
- El tratamiento sea necesario para proteger intereses vitales
- Sean datos de miembros tratados por una fundación, una asociación o cualquier otro organismo sin ánimo de lucro, cuya finalidad sea política, filosófica, religiosa o sindical, siempre que los datos personales no se comuniquen fuera de ellos sin el consentimiento de los interesados
- El tratamiento se refiera a datos personales que el interesado ha hecho manifiestamente públicos
- El tratamiento sea necesario para la gestión de reclamaciones o cuando los tribunales actúen en ejercicio de su función judicial
- El tratamiento sea necesario por razones de un interés público esencial
- El tratamiento sea necesario para fines médicos y de asistencia sanitaria, por un profesional sujeto a la obligación de secreto profesional
- Por razones de interés público en el ámbito de la salud pública
- El tratamiento se realice con fines de archivo en interés público, fines de investigación científica o histórica o fines estadísticos

Por otra parte, aunque no se incluyen dentro de las categorías especiales de datos, el tratamiento de datos personales relativos a condenas e infracciones penales o medidas de seguridad conexas solo podrá llevarse a cabo bajo la supervisión de las autoridades públicas o cuando lo autorice el Derecho de la Unión o de los Estados miembros.

3.5 Cumplimiento basado en la responsabilidad proactiva

El Reglamento se aleja de la concepción exhaustiva y detallada de la LOPD derogada, más propia del derecho romano y continental en Europa, en la que se detallaba punto por punto todo lo que debía cumplir el responsable según el nivel de riesgo de los datos que estaba tratando (para lo cual - establecer el nivel- también aportaba unas indicaciones tasadas y precisas).

En su lugar, el RGPD se aproxima más a las características del derecho anglosajón. La normativa es menos concisa, propone las obligaciones del responsable a un nivel más alto, y aporta un enfoque basado en el cumplimiento demostrable. En ese sentido puede complicar la tarea a los responsables y a las autoridades de control, pero resulta inevitable, al jugarse sobre un terreno tan variable y cambiante, soportado por las posibilidades de las TIC, donde no se puede detallar de forma estática lo que debe cumplirse punto por punto.

Esto es lo que se viene a llamar en el Reglamento la *responsabilidad proactiva*, más familiar como se ha indicado en el mundo legislativo anglosajón, donde se usa el término «Accountability», y que se podría resumir en una frase: la responsabilidad del cumplimiento y la capacidad de demostrarlo recae en el responsable.

Cómo se ha expuesto anteriormente, los ficheros ya no son un elemento relevante en la normativa vigente, apenas se citan en el Reglamento. No existe ya el registro de ficheros en la AEPD, la obligación de registrarlos desaparece, carece de sentido cuando no hay un enfoque ya basado en ficheros, sino en tratamientos. En su lugar aparecen otra serie de obligaciones que debe materializar el responsable con vistas a satisfacer esa doble vertiente de la responsabilidad proactiva: cumplir y poder demostrar el cumplimiento.

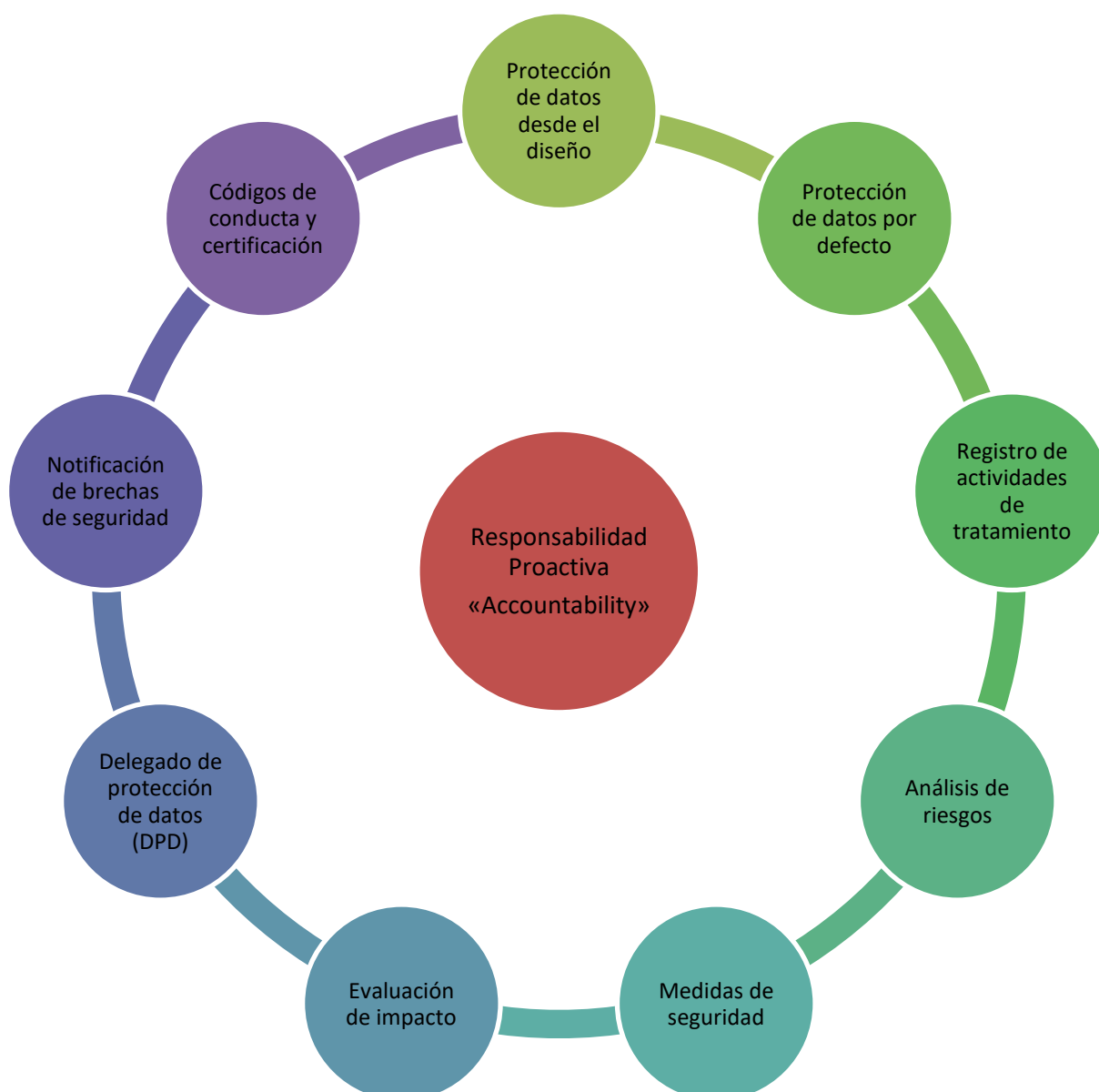


Figura 7 Responsabilidad proactiva

3.5.1 Protección de datos desde el diseño

La protección de datos desde el diseño supone que, desde las fases tempranas del proyecto, haya que considerar la protección de datos como un área de análisis.

Se deberán tener en cuenta y estudiar los requisitos correspondientes, y en los diseños se incluirán aquellas medidas que ayuden a cumplir las obligaciones y a velar por los derechos y libertades de los afectados cuyos datos se vayan a tratar.

Por ejemplo, una aplicación que gestione datos personales deberá permitir satisfacer los derechos de los interesados (acceso, supresión, portabilidad, etc.) e incorporar las medidas de seguridad que garanticen la integridad y la protección de los datos atendiendo al estado de la técnica. Entre estas medidas podrían estar el minimizar los datos personales tratados, así como seudonimizar lo antes posible esos datos, lo que realmente debe pensarse en una fase de concepción y diseño del proyecto.

Si se capturan correctamente los requisitos desde la concepción del proyecto, se traducirán en medidas técnicas y organizativas conformes con el RGPD de una forma más natural en el producto o servicio desarrollado, y se evitarán sobrecostes y/o agujeros de seguridad por su introducción tardía en el proyecto.

La obligación de que se adopten los principios de privacidad desde el diseño recae en el responsable del tratamiento. Sea cual sea la forma de subcontratación o adquisición de un proyecto o un producto, el responsable nunca podrá delegar completamente sus obligaciones de aplicación de este principio, ya que siempre quedará bajo su poder de decisión al menos aquellas medidas organizativas que le compete tomar para interaccionar con el servicio subcontratado.

El principio de la protección de datos desde el diseño, así como el siguiente, de protección de datos por defecto, deben tenerse en cuenta en los contratos públicos.

3.5.2 Protección de datos por defecto

Este segundo principio, ligado al anterior en el Reglamento, implica que, por defecto, solo sean objeto de tratamiento los datos personales que sean necesarios para cada uno de los fines específicos del tratamiento. Esta obligación se aplicará a la cantidad de datos personales recogidos, a la extensión de su tratamiento, a su plazo de conservación y a su acceso.

Independientemente del conjunto de datos recogidos por el responsable, el responsable ha de compartimentar el uso del conjunto de datos entre los distintos tratamientos, de tal forma que no todos los tratamientos accedan a todos los datos, sino que actúen solo sobre aquellos que sean necesarios y en los momentos en que sea estrictamente necesario.

El principio de «necesidad de conocer» se aplica a la protección de datos de carácter personal en la medida en que los empleados de la empresa sólo han de tener acceso a los datos personales que sean estrictamente necesarios para realizar su trabajo.

3.5.3 Registro de actividades de tratamiento

Esta medida sustituye a la antigua obligación de registrar los ficheros en la AEPD. Es similar en tanto en cuanto obliga a llevar una relación de los tratamientos y sus características asociadas, pero ya no tiene un enfoque en el fichero, ni exige su comunicación a ninguna autoridad administrativa. Es un registro interno del responsable que le facilitará el cumplimiento, al tener un listado de todos los tratamientos que realiza, y además le facilitará también demostrar el cumplimiento de la normativa ante la autoridad de control, a cuya disposición se debe poner siempre que lo solicite.

Dicho registro deberá constar por escrito y contener la siguiente información:

- a) Datos del responsable y del DPD
- b) Fines del tratamiento
- c) Categorías de interesados
- d) Categorías de datos personales tratados
- e) Categorías de destinatarios a quien se comunican los datos
- f) Transferencias internacionales de datos, en su caso
- g) Plazos del tratamiento hasta su supresión
- h) Medidas técnicas y organizativas de seguridad

Los encargados del tratamiento también deberán llevar un registro de las actividades de tratamiento efectuadas por cuenta del responsable. A diferencia del contenido del registro para responsables del tratamiento, en este caso solo deberá incluir los puntos d), f) y h), y además deberá incluir el nombre de cada responsable que le encarga el tratamiento.

Se libera a las PYMES de la obligación de llevar este registro (en concreto a empresas u organizaciones de menos de 250 personas), a menos que se cumpla alguna de las siguientes condiciones:

- El tratamiento pueda entrañar un riesgo para los derechos y libertades de los interesados
- No sea ocasional
- Incluya categorías especiales de datos personales
- Incluya datos de condenas o infracciones penales

3.5.4 Análisis de riesgos

Como ya se ha indicado, el Reglamento responde al reto de la evolución tecnológica estableciendo una responsabilidad proactiva por parte del responsable del tratamiento para definir las medidas de seguridad adecuadas (en lugar de listar con detalle las medidas obligadas para cada caso como hacía la normativa derogada). Pues bien, una vez realizado un registro de actividades que identifique todos los tratamientos de datos personales, el primer paso para que el responsable pueda definir las medidas de seguridad adecuadas es realizar un análisis de riesgos de esos tratamientos, que debe hacerse y mantenerse de forma continuada.

Por tanto, el objetivo principal del análisis de riesgos es el de establecer las medidas de seguridad y control en los tratamientos, para garantizar los derechos y libertades de las personas.

Escapa al objetivo de este tema explicar cómo se realiza un análisis y gestión de riesgos, por medio del cual se busca identificar las amenazas, evaluar los riesgos y tratarlos/mitigarlos. Sí que debe indicarse que, enfocándose en la protección de datos, los riesgos que se deben analizar no son los que se materializan sobre la compañía, si no sobre los derechos y libertades de las personas. Por tanto, las preguntas que el responsable se debe hacer deben valorar el impacto que, de materializarse las amenazas, tendrían sobre los interesados. Se recorrerán las distintas dimensiones de la seguridad, en especial la Confidencialidad (accesos ilegítimos a los datos), la Integridad (modificaciones no autorizadas) y la Disponibilidad (eliminación de los datos) para realizar un completo análisis de riesgos.

Algunos ejemplos de daños y perjuicios para el interesado los da el propio Reglamento en su considerando 75: discriminación, usurpación de identidad o fraude, pérdidas financieras, daño para la reputación, pérdida de confidencialidad de datos sujetos al secreto profesional, o no poder ejercer el control sobre sus datos personales.

También aporta una serie de elementos que deben considerarse para establecer el nivel de riesgo, en particular cuando los tratamientos tengan alguna de las siguientes características, por cuanto entrañan mayores riesgos para los derechos y libertades de las personas:

- Traten categorías especiales de datos, o sobre condenas e infracciones penales o medidas de seguridad conexas
- Creen o utilicen perfiles personales
- Se refieran a personas vulnerables, en particular niños
- El tratamiento implique una gran cantidad de datos personales y afecte a un gran número de interesados

3.5.5 Medidas de seguridad

Si se recorriese el marco normativo derogado, este apartado sería sin duda uno de los más detallados. Sin embargo, al lector ya no le sorprenderá que en el Reglamento no tenga casi recorrido por el nuevo enfoque basado en la responsabilidad proactiva, regulando esta materia en un artículo, el 32, de algo menos de media página. Esto, que puede generar inquietud al responsable de un tratamiento por dejar de su lado la responsabilidad del cumplimiento, aliviará sin duda al opositor, que no deberá aprenderse de memoria varios listados de medidas de seguridad.

El Reglamento se limita a establecer que las medidas de seguridad atenderán a los resultados del análisis de riesgos, y que serán las adecuadas según:

- El estado de la técnica
- Los costes de aplicación
- La naturaleza, alcance, contexto y fines del tratamiento

Las medidas, técnicas y organizativas, deben asegurar un nivel de seguridad apropiado para el riesgo identificado, incluyendo entre otros:

- La seudonimización y el cifrado de los datos
- La garantía sobre la Confidencialidad, Integridad, Disponibilidad y Resiliencia de los sistemas y servicios
- La capacidad de restaurar la disponibilidad y el acceso a los datos rápidamente en caso de incidente
- El proceso de verificación regular de las medidas

3.5.6 Evaluación de impacto

La Evaluación de Impacto en la Protección de Datos Personales (EIPD, o DPIA por sus siglas en inglés) es un instrumento que permite evaluar de manera anticipada cuáles son los potenciales riesgos a los que están expuestos los datos personales en función de las actividades de tratamiento que se llevan a cabo con los mismos.

El RGPD prevé que las Evaluaciones de Impacto se lleven a cabo antes de iniciar el tratamiento, en los casos en que sea probable que exista un alto riesgo para los derechos y libertades de los afectados, y en particular en caso de:

- Evaluación sistemática y exhaustiva de datos personales de forma automatizada, como la elaboración de perfiles, sobre cuya base se tomen decisiones con efectos jurídicos o les afecten significativamente
- Tratamiento a gran escala de categorías especiales de datos, o datos de condenas o infracciones penales
- Observación sistemática a gran escala de una zona de acceso público

Según el órgano consultivo GT29 (o WP29 en inglés, asumidas sus funciones por el Comité Europeo de Protección de Datos desde el 25 de mayo de 2018), para determinar si un tratamiento es a gran escala se debe considerar:

- El número de interesados involucrados, bien como cifra concreta o como proporción de la población correspondiente
- El volumen de datos o el abanico de diferentes conceptos de datos que se procesan

- La duración de la actividad de tratamiento de datos
- El alcance geográfico de la actividad de tratamiento

Por otra parte, las autoridades de control nacionales publicarán una lista de tratamientos que necesariamente requieran una evaluación de impacto, y podrán opcionalmente establecer una lista que no requieran dicha evaluación.

El resultado de la EIPD se debe tener en cuenta, necesariamente, a la hora de tomar las decisiones relacionadas con el cumplimiento de lo previsto en el RGPD, y para tomar la decisión acerca de la viabilidad o no de llevar a cabo el tratamiento de los datos.

En todo caso, la EIPD deberá incluir como mínimo:

- Una descripción sistemática de las operaciones de tratamiento previstas
- Una evaluación de la necesidad y proporcionalidad del tratamiento respecto a su finalidad
- Una evaluación de los riesgos
- Las medidas previstas para afrontar los riesgos, incluidas garantías, medidas de seguridad y mecanismos que garanticen la protección de datos personales

Cuando una EIPD muestre que el tratamiento entrañaría un alto riesgo aún tras aplicar las garantías, medidas de seguridad y mecanismos de protección, el responsable estará obligado a consultar a la autoridad de control antes de iniciarlo. La autoridad de control asesorará al responsable por escrito, y podrá utilizar cualquiera de los poderes otorgados por el Reglamento, que incluyen ordenar adaptaciones y/o emitir una advertencia cuando las operaciones de tratamiento previstas puedan infringir lo dispuesto en el Reglamento.

3.5.7 Delegado de protección de datos

Es esta una figura creada por el RGPD que resulta clave en el enfoque de cumplimiento basado en la responsabilidad proactiva, tanto para informar y asesorar al responsable, como para supervisar el cumplimiento, como para relacionarse con interesados y autoridad de control.

Se desarrollará en un capítulo aparte de este tema, dada su relevancia y por constituir un epígrafe individualizado en el temario.

3.5.8 Notificación de brechas de seguridad

El Reglamento define las violaciones de seguridad de los datos personales como toda violación de la seguridad que ocasione la destrucción, pérdida o alteración accidental o ilícita de datos personales, o la comunicación o acceso no autorizados a dichos datos.

Cabe destacar que siempre que hablemos de brechas o violaciones de seguridad en el contexto del RGPD, se hace referencia a aquellas que afecten a datos personales. El resto de incidentes de seguridad no están afectados por esta normativa.

El Reglamento introduce una nueva obligación para los responsables: notificar las violaciones de seguridad de los datos personales a la autoridad de control. Es una obligación que se extiende, puesto que ya existía para los operadores de telecomunicaciones al amparo de la Directiva 2002/58/CE, en nuestro país incluida en la Ley 9/2014, General de Telecomunicaciones.

Se establece que debe notificarse siempre, a menos que sea improbable que constituya un riesgo para los afectados, y a más tardar 72 horas después de que el responsable haya tenido constancia de ella. Si la notificación a la autoridad de control no tiene lugar en plazo, deberá ir acompañada de indicación de los motivos de la dilación. Se podrán hacer comunicaciones complementarias con posterioridad, para completar la información proporcionada en las primeras 72 horas.

La comunicación de la brecha incluirá al menos la siguiente información:

- a) La naturaleza de la violación
- b) Categoría y número de afectados
- c) Categoría y número de registros afectados
- d) Contacto del DPD u otro punto de contacto
- e) Posibles consecuencias
- f) Medidas adoptadas o propuestas para poner remedio y mitigar los efectos

Por su parte, el encargado del tratamiento notificará sin dilación al responsable del tratamiento de las brechas de seguridad de las que tenga conocimiento.

Además de a la autoridad de control, el responsable deberá comunicarlo a los afectados cuando sea probable que la brecha entrañe un alto riesgo para los derechos y libertades de las personas físicas, a menos que:

- Se hayan tomado las medidas de protección que hagan ininteligibles los datos personales (como el cifrado)
- Se hayan tomado medidas posteriores que hagan que ya no exista ese riesgo
- Suponga un esfuerzo desproporcionado, en cuyo caso se deberá optar por una comunicación pública o semejante

3.5.9 Códigos de conducta y certificación

El último elemento que se debe destacar en torno a la responsabilidad proactiva es el de los códigos de conducta y mecanismos de certificación. Ambos son ejemplos de autorregulación, y se pueden usar como elemento para demostrar el cumplimiento de las obligaciones por parte de responsables y encargados.

3.5.9.1. Códigos de conducta

Los códigos de conducta podrán ser elaborados por asociaciones y otros organismos representativos de categorías de responsables y encargados, para los que serán vinculantes una vez adheridos a los códigos de conducta.

Los códigos de conducta adaptarán la aplicación del Reglamento a las características y necesidades de los distintos sectores de actividad, pymes o micro pymes, en lo que respecta a:

- El tratamiento leal y transparente
- Los intereses legítimos perseguidos por los responsables del tratamiento en contextos específicos
- La recogida de datos personales
- La seudonimización de datos personales
- La información proporcionada al público y a los interesados
- El ejercicio de los derechos de los interesados
- La información proporcionada a los niños y la protección de éstos, así como la manera de obtener el consentimiento de los titulares de la patria potestad o tutela sobre el niño
- Las medidas y procedimientos para garantizar la seguridad del tratamiento, así como la protección de datos desde el diseño y por defecto
- La notificación de violaciones de la seguridad de los datos personales a las autoridades de control y la comunicación de dichas violaciones a los interesados
- La transferencia de datos personales a terceros países y organizaciones internacionales
- Los procedimientos extrajudiciales y otros procedimientos de resolución de conflictos que permitan resolver las controversias entre los responsables del tratamiento y los interesados relativos al tratamiento

Asimismo, deberán incluir mecanismos que permitan efectuar el control obligatorio de cumplimiento por un organismo de supervisión propio, acreditado por la autoridad de control (sin perjuicio de las funciones y poderes de la autoridad de control).

Los proyectos de código serán remitidos a la autoridad de control, que deberá emitir un dictamen sobre el mismo en cuanto a su conformidad con el Reglamento.

3.5.9.2. Mecanismos de certificación

El Reglamento establece expresamente que, para aumentar la transparencia y el cumplimiento del mismo, debe fomentarse el establecimiento de mecanismos de certificación y sellos y marcas de protección de datos que permitan a los interesados evaluar con mayor rapidez el nivel de protección de datos de los productos y servicios correspondientes.

Por ello insta a los Estados Miembros, autoridades de control, Comité y Comisión a promover, en particular a nivel de la Unión, la creación de mecanismos de certificación en materia de protección de datos y de sellos y marcas de protección de datos a fin de demostrar el cumplimiento del Reglamento en las operaciones de tratamiento. No obstante, la certificación será voluntaria.

La certificación se expedirá a un responsable o encargado por parte de un organismo de certificación acreditado o por la autoridad de control, por un período máximo de tres años, y podrá ser renovada en las mismas condiciones, siempre y cuando se sigan cumpliendo los requisitos pertinentes.

3.6 Transferencias de datos a terceros países

Por transferencias a terceros países, se entienden los flujos de datos personales a países donde no aplica el RGPD. Esto, es, fuera de la UE, y de los tres países del EEE que lo han adoptado.

Los responsables y encargados del tratamiento podrán realizar transferencias internacionales de datos siempre que el tratamiento de datos observe lo dispuesto en el RGPD y se den los siguientes supuestos:

- a) Destinatario declarado de nivel adecuado por la Comisión Europea, sin necesidad de autorización por la autoridad de control
 - En la actualidad, la lista de países incluye Suiza, Canadá, Argentina, Guernsey, Isla de Man, Jersey, Islas Feroe, Andorra, Israel, Uruguay, Nueva Zelanda, Estados Unidos y Japón.
 - En el caso de Estados Unidos, solo para las entidades certificadas en el marco del Escudo de Privacidad («Privacy Shield»).
- b) En ausencia de decisión, solo si el responsable o encargado provee las garantías apropiadas, que pueden ser garantizadas por:
 - Un instrumento jurídicamente vinculante y exigible entre las autoridades u organismos públicos
 - Normas corporativas vinculantes: son políticas de protección de datos, aprobadas por la autoridad de control competente, que son asumidas por un responsable o encargado para transferencias dentro de un mismo grupo
 - Cláusulas tipo de protección de datos adoptadas por la Comisión, o adoptadas por una autoridad de control y aprobadas por la Comisión
 - Códigos de conducta
 - Mecanismos de certificación
 - Cláusulas contractuales entre el responsable y el encargado o el destinatario (en este caso se necesitará autorización expresa de la autoridad de control para realizar la transferencia)

- Disposiciones que se incorporen en acuerdos administrativos (en este caso se necesitará autorización expresa de la autoridad de control para realizar la transferencia)
- c) En ausencia de decisión o garantías, solo se podrá realizar la transferencia en los siguientes supuestos:
 - El interesado ha dado explícitamente su consentimiento
 - Para la ejecución de un contrato entre el interesado y el responsable
 - Para la celebración o ejecución de un contrato, en interés del interesado, entre el responsable del tratamiento y un tercero
 - Por razones importantes de interés público
 - Para la formulación, el ejercicio o la defensa de reclamaciones legales
 - Para proteger los intereses vitales del interesado o de otras personas, cuando el interesado esté incapacitado para consentir
 - La transferencia se realiza desde un registro público que tenga por objeto facilitar información al público y esté abierto a la consulta del público

Cuando tampoco sea aplicable ninguno de estos supuestos, solo se podrá llevar a cabo una transferencia si no es repetitiva, afecta a un número limitado de interesados, es necesaria para fines de interés legítimo imperioso del responsable sobre los que no prevalezcan los intereses o derechos y libertades del interesado, y el responsable ofrezca garantías apropiadas. En este supuesto, el responsable del tratamiento informará a la autoridad de control de la transferencia, así como al interesado.

3.7 Cooperación y coherencia transfronteriza

El RGPD establece mecanismos de cooperación y coherencia para permitir la asistencia mutua entre autoridades de control y para garantizar una aplicación uniforme del Reglamento en todo el territorio.

El Reglamento introduce la figura de tratamiento transfronterizo, siendo aquel tratamiento que cumple alguna de las siguientes condiciones:

- a) Se da en el contexto de actividades de establecimientos del responsable o encargado en varios Estados miembros
- b) O bien aquel que, dándose en un solo establecimiento, afecta a interesados en varios Estados

Por ejemplo, una empresa con establecimientos en España y Portugal, si el tratamiento de datos personales tiene lugar en el contexto de sus actividades en ambos países, entonces es un tratamiento transfronterizo. Facebook, con un establecimiento principal en Irlanda que es centro de operaciones para toda Europa, también realiza un tratamiento transfronterizo en la medida en que afecta a ciudadanos, sean o no europeos, que se encuentren en varios Estados de la Unión (o del EEE).

Aquellas compañías sin establecimientos en Europa están obligadas a designar un representante si ofrecen productos o servicios a personas que se encuentren en la Unión. Sin embargo, los mecanismos de cooperación y coherencia solo aplican a responsables establecidos en la UE, por tanto, en estos casos, el responsable tratará con cada autoridad de control de forma local.

En el caso de los tratamientos realizados por las Administraciones Públicas, siempre se tratarán como casos locales.

3.7.1 Mecanismo de ventanilla única

En un tratamiento transfronterizo se ha de designar una autoridad de control *principal*, que es la autoridad de control del establecimiento principal o del único establecimiento del responsable o encargado del tratamiento, y que será competente para tratar las reclamaciones relacionadas con aquel

responsable o encargado. Es lo que se conoce como mecanismo de ventanilla única, o «one-stop shop».

El resto de las autoridades, en la medida en que tengan otros establecimientos o ciudadanos afectados por el tratamiento en su país, se constituirán como autoridades de control *interesadas*. Sin perjuicio de que en caso de que una reclamación se refiera únicamente a un establecimiento situado en su país o únicamente afecte a interesados en su país, tenga competencia para tratar ese caso, por considerarse esto un caso local y no transfronterizo.

Entre las autoridades de control se seguirá el procedimiento marcado en el artículo 60 para resolver las reclamaciones, que pasa porque la autoridad principal comparta el proyecto de decisión con las interesadas, que podrán poner objeciones al mismo que deberán ser tenidas en cuenta.

3.7.2 Asistencia mutua

En todo caso, ya sea un tratamiento local o transfronterizo, las autoridades de control deberán prestarse asistencia mutua a fin de aplicar el Reglamento de forma coherente y para asegurar una efectiva cooperación entre ellas. Esta asistencia seguirá el procedimiento dictado en el artículo 61 del RGPD, y podrá incluir la realización de operaciones conjuntas, incluidas investigaciones conjuntas y medidas de ejecución conjuntas, en las que participen miembros o personal de las autoridades de control de otros Estados miembros, como prevé el artículo 62 del Reglamento.

3.7.3 Mecanismo de coherencia

Además de la cooperación prevista en los artículos 60 a 62, el Reglamento también establece un mecanismo de coherencia, a fin de contribuir la aplicación coherente del Reglamento en toda la Unión. Este mecanismo se articula en torno al Comité Europeo de Protección de Datos (CEPD).

3.7.3.1. Comité Europeo de Protección de Datos

El Reglamento, en su artículo 68, crea el Comité Europeo de Protección de Datos, como organismo de la Unión, que gozará de personalidad jurídica.

El Comité está compuesto por el director de una autoridad de control de cada Estado miembro (en España, el director/a de la AEPD) y por el Supervisor Europeo de Protección de Datos (el organismo de supervisión para los tratamientos de instituciones y organismos de la UE). Además, el Comité contará con una Secretaría, de la que se hará cargo el Supervisor Europeo de Protección de Datos, y que prestará apoyo analítico, administrativo y logístico al Comité.

La misión principal del Comité es la de garantizar la aplicación coherente del Reglamento. Para ello tiene entre sus funciones la de asesorar, examinar, y emitir directrices y dictámenes. Además, tomará decisiones vinculantes cuando existan conflictos o puntos de vista contrarios entre las autoridades de control.

3.8 Régimen sancionador

Uno de los elementos del nuevo Reglamento que más llamó la atención en los medios de comunicación fue la capacidad sancionadora en forma de multas, y la alta cuantía de las mismas. En efecto, el RGPD aumenta de forma importante el importe de las sanciones económicas, pero al mismo tiempo aporta una mayor variedad de poderes correctivos distintos de la multa administrativa como se verá a continuación.

3.8.1 Sujetos afectados

Estarán sujetos al régimen sancionador del Reglamento tanto los relacionados directamente con el tratamiento de datos como los relacionados con los mecanismos de garantía del correcto tratamiento de datos:

- Los responsables del tratamiento
- Los encargados del tratamiento
- Los representantes de responsables o encargados no establecidos en la UE
- Las entidades de certificación
- Los supervisores de códigos de conducta

3.8.2 Poderes de investigación y correctivos

Las autoridades de control tendrán los siguientes poderes de investigación:

- a) Ordenar a responsables y encargados o representantes de estos que faciliten la información necesaria
- b) Llevar a cabo investigaciones en forma de auditorías
- c) Revisar las certificaciones expedidas
- d) Notificar al responsable o encargado las presuntas infracciones del Reglamento
- e) Obtener acceso a los datos personales tratados
- f) Obtener acceso a los locales, equipos y medios de tratamiento

Por otra parte, los poderes correctivos que tienen las autoridades de control ante una supuesta infracción del Reglamento incluyen:

- a) Ordenar adaptaciones al RGPD en un plazo determinado
- b) Ordenar la atención de derechos
- c) Ordenar rectificación, limitación o supresión de los datos, o la limitación del tratamiento
- d) Sancionar con advertencia cuando el tratamiento previsto pueda infringir el Reglamento (para los casos de consulta previa)
- e) Sancionar con apercibimiento
- f) Imponer limitación del tratamiento temporal o definitiva
- g) Sancionar con multa

Las multas administrativas y los apercibimientos pueden imponerse en lugar de, o además de, otras medidas.

3.8.2.1. Multas administrativas

El Reglamento establece en su artículo 83 que las multas deben ser efectivas, proporcionadas y disuasorias, y que al decidir su cuantía se deben considerar una serie de elementos, entre los que están:

- La naturaleza, gravedad y duración de la infracción
- La intencionalidad o negligencia
- Medidas tomadas para paliar los daños y perjuicios
- El grado de responsabilidad del responsable o encargado
- Toda infracción anterior
- El grado de cooperación con la autoridad de control
- Las categorías de datos personales afectados
- La forma en que la autoridad de control tuvo conocimiento de la infracción
- El cumplimiento de medidas previas
- La adhesión a códigos de conducta o mecanismos de certificación

- Cualquier otro factor agravante o atenuante aplicable a las circunstancias, como los beneficios financieros

A continuación, determina dos umbrales de sanción en función de los tipos de infracción:

- a) Multa de hasta 10 millones de € o hasta el 2% de volumen de negocio anual global, para infracciones relacionadas con:
 - Obligaciones del responsable o encargado
 - Obligaciones de organismos de certificación
 - Obligaciones de organismos de supervisión de códigos de conducta
- b) Multa de hasta 20 millones de euros o hasta el 4% del volumen de negocio anual global, para infracciones relacionadas con:
 - Los principios básicos
 - Derechos del interesado
 - Transferencias internacionales
 - Incumplimiento de resoluciones de la autoridad de control

3.9 Conclusión

El RGPD es la figura normativa y referencia principal de la protección de datos personales en toda la Unión, de aplicación directa en todos los Estados de la UE, primando sobre las leyes nacionales, y además dejando solo lugar a su complementación o desarrollo nacional en aspectos concretos. Por tanto, en el RGPD se encuentra el núcleo de la normativa de protección de datos y las claves para su comprensión y cumplimiento. Entre ellas, destacan los principios rectores, los derechos del interesado y el novedoso desarrollo de la responsabilidad proactiva y el enfoque basado en riesgo como elemento de cumplimiento y demostración del cumplimiento.

Una vez recorrido el marco normativo del RGPD, para finalizar y a modo de repaso y concusión, se propone en este apartado un flujo lógico que podría seguir un organismo público o una entidad privada para adecuar su estructura y procedimientos al RGPD:

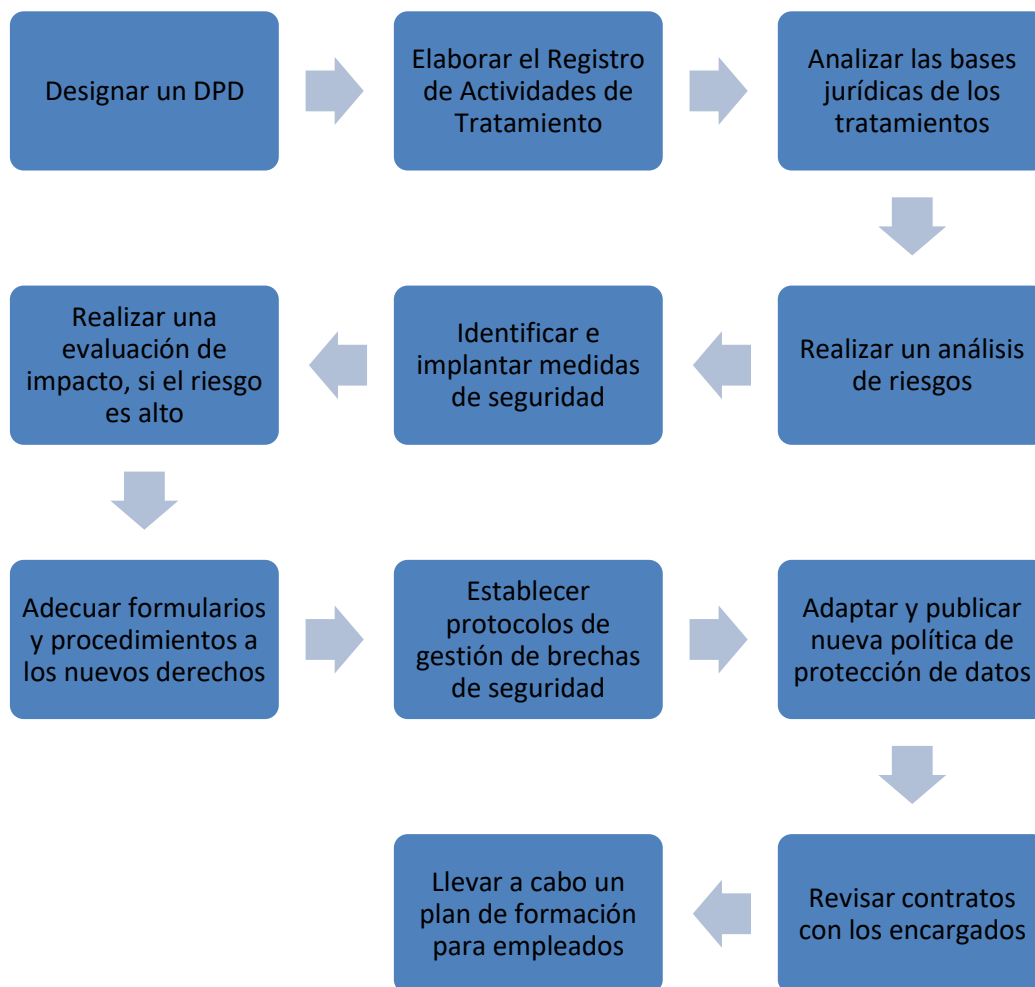


Figura 8 Adaptación al RGPD

4 Política de protección de datos

4.1 Introducción

Como hemos visto, todo responsable que realice tratamientos de datos debe cumplir el principio de transparencia, por el cual informará de todos los términos del tratamiento que realiza. Esto se materializa y se recopila en su conjunto en la política de protección de datos, habitualmente incluida dentro de la política de privacidad.

4.2 Contenido de la política

Una política de protección de datos debe incluir los siguientes puntos:

	Identidad y datos de contacto del responsable, junto con los datos del DPD en su caso		Finalidades del tratamiento, y la base jurídica que legitima cada actividad
	Plazo de conservación de los datos personales		Información sobre los derechos del interesado y cómo ejercerlos
	Si se van a realizar cesiones de datos a terceros, deben identificarse		Información sobre la obligatoriedad de suministrar los datos personales o parte de ellos (obligación legal o contractual)
	Información sobre la posible elaboración de perfiles y la toma de decisiones automatizadas, y las consecuencias para el interesado		Información sobre las transferencias de datos a terceros países, incluyendo el marco que da soporte y garantías a la transferencia

Figura 9 Política de protección de datos

Esta información sobre el tratamiento debe facilitarse al interesado de forma clara y concisa, evitando fórmulas ambiguas o innecesariamente extensas, teniendo en cuenta que el objetivo final es que el usuario pueda tomar decisiones informadas sobre la utilización de sus datos personales.

Los consentimientos necesarios para legitimar alguna de las actividades de tratamiento deben recogerse de forma diferenciada a la aceptación de la política de privacidad en su conjunto.

4.3 Conclusión

Es importante saber redactar una política de protección de datos, que debe hacerse pública, para la comprensión por parte de todos los afectados por los tratamientos.

Pueden encontrarse múltiples ejemplos de políticas de privacidad publicadas en las páginas web de empresas privadas y organismos públicos. La propia AEPD mantiene publicada su política en su página web y, para indicar los detalles específicos de cada actividad de tratamiento, remite al registro de actividades de tratamiento, que también ha hecho público en la misma página cumpliendo la obligación impuesta por el artículo 31.2 de la LOPDGDD.

5 La Ley Orgánica de Protección de Datos

5.1 Introducción

La ley Orgánica 3/2018, de Protección de Datos Personales y garantía de los derechos digitales, entró en vigor el 7 de diciembre de 2018, como consecuencia directa de la aplicación del RGPD el 25 de mayo del mismo año, que dejaba el derecho español y en concreto la ley 15/1999 inadaptada a dicho marco jurídico.

En términos competenciales nacionales, la ley se dicta al amparo del artículo 149.1.1 de la Constitución, que atribuye al Estado la competencia exclusiva para la regulación de las condiciones básicas que garanticen la igualdad de todos los españoles en el ejercicio de los derechos y en el cumplimiento de los deberes constitucionales

Aun considerando que el RGPD ya era de aplicación directa y además primando sobre la normativa nacional, una ley nacional seguía siendo necesaria, y así se ha hecho en todos los Estados miembros de la UE, para completar los siguientes objetivos:



Figura 10 Objetivos de la LOPDGDD

En los siguientes apartados se pondrán de manifiesto aquellos elementos que añade la LOPDGDD sobre el marco de referencia que constituye el RGPD.

5.2 Disposiciones sobre tratamientos concretos

En el artículo 6.1 del RGPD se enumeran una serie de supuestos bajo los cuales un tratamiento de datos personales sería lícito. Entre ellos, para responsables del sector privado, está la satisfacción de sus intereses legítimos, siempre que no prevalezcan los intereses o derechos y libertados de los

interesados. Este punto no está siempre claro y puede dar inseguridad a los responsables sobre en qué medida sus intereses prevalecen.

Adicionalmente, el artículo 6.3 establece que en caso de que la licitud del tratamiento se fundamente en el cumplimiento de una obligación legal o en el cumplimiento de una misión pública o ejercicio de poderes públicos, estas deben ser establecidas por el Derecho de la UE o de los Estados miembros.

Por todo ello, la LOPDGDD realiza una serie de disposiciones sobre tratamientos específicos buscando dar esa seguridad jurídica a los responsables, que podrán realizar dichos tratamientos siempre que cumplan con las garantías indicadas. Recordemos que, si el tratamiento posee otra base de legitimación, no es necesario tener consentimiento por parte de los interesados.

5.2.1 Datos de contacto de empleados y autónomos

El RGPD no excluye de su ámbito los listines profesionales como sí hacía la normativa precedente, pero lo que sí hace la LOPDGDD es reconocer el interés legítimo para su tratamiento. Por tanto, es lícito el tratamiento de los datos de contacto de empleados de una empresa. Para ello, deberán cumplirse las siguientes garantías:

- Que los datos sean los imprescindibles para su localización profesional
- Que la finalidad sea la de mantener relaciones con la empresa a la que pertenecen

La ley extiende esta presunción de legitimidad a los datos de empresarios individuales y profesionales liberales (autónomos) en tanto se refieran a ellos en dicha condición, y no como personas físicas.

Si el responsable es un organismo público, solo podrá tratar estos datos cuando el tratamiento se derive de una obligación legal o sea necesario para el ejercicio de sus competencias.

5.2.2 Sistemas de información crediticia

Se presume lícito el tratamiento de datos personales relacionados con la morosidad (las conocidas como listas de morosos, con información de incumplimientos de obligaciones), cumpliendo las siguientes garantías:

- Los datos hayan sido provistos por el acreedor
- Se refieran a deudas ciertas, vencidas y exigibles, que no estén siendo recurridas
- El acreedor haya informado al afectado en el contrato o al requerir el pago de la posibilidad de su inclusión en dichos sistemas
- La entidad que gestione el sistema debe notificar al afectado de su inclusión y de los derechos que le asisten
- Los datos se conservarán mientras persista el incumplimiento, con un máximo de 5 años
- Los datos solo podrán consultarse por quien mantenga un contrato o vaya a iniciar un contrato con el afectado que suponga un abono pecuniario
 - o En caso de denegarse el contrato, se deberá informar al interesado del resultado de dicha consulta
- No se incorporarán deudas de cuantía inferior a 50 euros

5.2.3 Operaciones mercantiles

Se legitiman las cesiones de datos entre compañías que se deriven de la modificación estructural de sociedades (absorciones, adquisiciones, fusiones), siempre que sean necesarios para el buen fin de la operación y garanticen la continuidad de los servicios.

5.2.4 Videovigilancia

Se legitima el tratamiento de imágenes de cámaras y videocámaras con la finalidad de preservar la seguridad de las personas y bienes, así como de sus instalaciones, si se dota de las siguientes garantías:

- No se podrán captar imágenes de la vía pública, o solo en la medida imprescindible (p.ej. una cámara que vigile un acceso y capte una parte mínima de la calle)
- Las imágenes deben suprimirse en un mes, salvo si ha ocurrido algún acto vandálico o delictivo, en cuyo caso deberán ponerse a disposición de las autoridades
- Para cumplir el deber de información se colocará un cartel informativo en lugar visible que avise de la captación de imágenes, el responsable y la posibilidad de ejercer los derechos
- También se debe avisar e informar cuando se realicen grabaciones por el empleador en el lugar de trabajo, que en ningún caso debe incluir las zonas de descanso (comedores, vestuarios, etc.)

Se excluyen de estas obligaciones los tratamientos realizados por personas físicas en su propio domicilio (como no puede ser de otra manera, dado que el Reglamento exceptúa los tratamientos domésticos) y los tratamientos realizados por Fuerzas y Cuerpos de Seguridad, que se rigen por su propia legislación.

5.2.5 Sistemas de exclusión publicitaria

Se legitima el tratamiento de datos con objeto de evitar el envío de comunicaciones comerciales (las conocidas como Listas Robinson), dotándose de las siguientes garantías:

- Incluirán únicamente los datos imprescindibles para identificar a los afectados
- Comunicarán a la autoridad de control su creación, que los hará públicos en su sede electrónica
- Quienes realicen comunicaciones de marketing directo están obligados a consultar estas listas y excluir a los interesados que así hayan manifestado su oposición (a menos que el afectado haya consentido recibir dicha comunicación)

5.2.6 Sistemas de denuncias internas

Se legitima la creación de sistemas de información para la realización de denuncias dentro de una entidad privada, incluso anónimas, de actos que puedan ser contrarios a la normativa general o sectorial aplicable, con las siguientes garantías:

- Se deberá informar a los empleados y terceros
- El acceso será limitado a quienes realicen las funciones de control interno y cumplimiento
- Se preservará la identidad y confidencialidad de los datos de las personas afectadas
- Se conservarán los datos durante el tiempo imprescindible para investigar los hechos, con un plazo máximo de tres meses
- Estos principios también aplicarán a los sistemas que puedan crearse en las Administraciones Públicas

5.2.7 Función estadística pública

El tratamiento por los órganos que tengan atribuida la función estadística pública se regirá por su legislación específica, además del RGPD y la LOPDGDD.

La comunicación de datos a dichos órganos se considerará amparada por el cumplimiento de una misión de interés público (artículo 6.1.e del RGPD) solo si la estadística a realizar está exigida por una norma de la UE o está incluida en instrumentos estadísticos legales.

Los datos que se encuentren dentro de las categorías especiales de datos o de infracciones penales sólo podrán recogerse previo consentimiento expreso de los afectados.

5.2.8 Archivo de interés público

Se legitima el tratamiento de datos con fines de archivo en interés público realizado por las Administraciones Públicas.

5.2.9 Infracciones y sanciones administrativas

El tratamiento de datos relativos a infracciones o sanciones administrativas debe cumplir las siguientes exigencias:

- Que los responsables sean los órganos competentes
- Que el tratamiento se limite a los datos estrictamente necesarios
- En caso de que no cumplan las condiciones anteriores, se deberá contar con el consentimiento del afectado o estar autorizados por una norma con rango de ley

Fuera de estos supuestos, se permite además el tratamiento por parte de abogados y procuradores de los datos de infracciones y sanciones de sus clientes.

5.2.10 Actividades electorales de partidos políticos

En la tramitación parlamentaria de la ley, se añadió una disposición adicional para regular la utilización de medios tecnológicos y datos personales en las actividades electorales. Esta disposición modifica la Ley Orgánica del Régimen Electoral General (LOREG) añadiendo un nuevo artículo (58 bis) que se compone de tres elementos:

- a) Legitima, en base al interés público, la recopilación de opiniones políticas por parte de los partidos políticos en el marco de sus actividades electorales, cuando se ofrezcan garantías adecuadas
 - Hay que recordar que las opiniones políticas son datos de especial categoría que no pueden tratarse, salvo excepciones, como es el interés público esencial
 - El Considerando 56 del RGPD apunta que si, en el marco de actividades electorales, el funcionamiento del sistema democrático exige en un Estado miembro que los partidos políticos recopilen datos personales sobre las opiniones políticas de las personas, puede autorizarse el tratamiento de estos datos por razones de interés público, siempre que se ofrezcan garantías adecuadas
- b) Indica que los partidos podrán utilizar datos personales obtenidos de páginas web y otras fuentes accesibles al público durante el período electoral para la realización de actividades políticas
 - Las fuentes accesibles al público no legitiman un tratamiento en el RGPD, como sucedía en el marco jurídico precedente, por tanto, tiene que haber otra base legítima, que es la que se habilita en este apartado
- c) Finalmente, establece que el envío de propaganda electoral no tendrá consideración de comunicación comercial, aunque se deberá facilitar de forma sencilla el derecho de oposición
 - Este punto exime a los responsables de las limitaciones que establece la LSSI para los envíos comerciales, y de otras obligaciones como consultar las listas de exclusión publicitaria (listas Robinson)
 - El derecho de oposición se puede ejercer en la sede electrónica del INE

La AEPD, haciendo uso de la potestad reglamentaria que le confiere la ley y que se revisará más adelante en este tema, ha publicado una Circular en el BOE, dado el debate y la preocupación respecto a los límites que deben aplicarse.

En esta Circular se determina que debe darse una interpretación restrictiva a dicho artículo: los partidos tienen que demostrar que realizan el tratamiento por interés público, no pueden realizar perfiles personalizados de los votantes y solo recabarán opiniones políticas libremente expresadas, en ningún caso tratarán otros datos personales para inferir la ideología política de una persona por medio de

técnicas de inteligencia artificial o Big Data. Asimismo, dicha recopilación se debe limitar al período electoral.

Finalmente, la Circular establece cuáles deben ser esas garantías adecuadas que cita el articulado.

5.2.11 Datos de salud

Los datos de salud pertenecen a las categorías especiales de datos que no se pueden tratar salvo excepciones. En el caso de este tipo de datos, las excepciones atribuibles son comúnmente las que se refieren al interés público esencial, fines de medicina preventiva o laboral, interés público en el ámbito de la salud pública o fines de investigación científica.

El tratamiento de datos personales en investigación será lícito si se cumple alguna de las siguientes condiciones:

- a) Si existe consentimiento del interesado para su uso en fines de investigación
- b) Sin el consentimiento, en situaciones de excepcional relevancia y gravedad
- c) Cuando se usen para un área de investigación relacionada con el área para la que se consintió inicialmente
- d) Si los datos están seudonimizados

5.3 Tratamientos por responsables públicos

En este apartado se incluyen una serie de particularidades de la ley que afectan a los tratamientos realizados por responsables o encargados del sector público.

5.3.1 Responsables públicos

En primer lugar, la LOPDGDD encuadra como responsables o encargados públicos los siguientes:

- Los órganos constitucionales y las instituciones de las comunidades autónomas análogas
- Los órganos jurisdiccionales
- La AGE, las Administraciones de las CCAA y las entidades de la Administración Local
- Los organismos públicos y entidades de Derecho público vinculadas o dependientes
- Las autoridades administrativas independientes
- El Banco de España
- Las corporaciones de Derecho público, cuando las finalidades del tratamiento se relacionen con el ejercicio de potestades de derecho público
- Las fundaciones del sector público
- Las Universidades Públicas
- Los consorcios
- Los grupos parlamentarios de las Cortes Generales y las Asambleas Legislativas autonómicas, así como los grupos políticos de las Corporaciones Locales

5.3.2 Bases de legitimación

Entre las bases de legitimación que incluye el RGPD para poder realizar un tratamiento de datos personales, hay dos que son las más comunes dentro de las Administraciones Públicas: por obligación legal, o por el cumplimiento de una misión de interés público o por el ejercicio de poderes públicos.

La LOPDGDD habilita y detalla dichas bases en su articulado.

5.3.2.1. Tratamiento por obligación legal

El tratamiento solo podrá fundamentarse en el cumplimiento de una obligación legal si está previsto en una norma de Derecho de la UE o una norma con rango de ley. No podrá fundamentarse la obligación legal por tanto en un reglamento del gobierno o de las Comunidades Autónomas, o en otra norma administrativa.

La ley o norma con rango de ley (Real Decreto Ley, Real Decreto Legislativo), podrá determinar condiciones y tipos de datos del tratamiento, así como medidas de seguridad adicionales.

5.3.2.2. Tratamiento por misión de interés público o ejercicio de poderes públicos

De manera equivalente, el tratamiento solo podrá fundamentarse en el cumplimiento de una misión en interés público o en el ejercicio de poderes públicos cuando derive de una competencia atribuida por una norma con rango de ley.

5.3.3 Potestad de verificación

Cuando se reciban solicitudes en las que el interesado declare datos personales que obren en poder de la Administración, se podrán efectuar en el ejercicio de sus competencias las verificaciones necesarias para comprobar la exactitud de los datos.

5.3.4 Registros de personal

Los registros de personal del sector público se entenderán realizados en el ejercicio de poderes públicos conferidos a sus responsables.

Podrán tratar datos relativos a infracciones y condenas penales e infracciones y sanciones administrativas, limitándose a los datos estrictamente necesarios para cumplir su finalidad.

5.3.5 Documentos aportados por los interesados

La LOPDGDD modifica el artículo 28 de la ley 39/2015, del Procedimiento Administrativo Común, que establece el derecho a no aportar documentos que obren en poder de la Administración. Se elimina la posibilidad de que el interesado se oponga a la consulta u obtención de documentos cuando la aportación del documento se exija en el marco del ejercicio de potestades sancionadoras o de inspección. En el resto de los procedimientos administrativos, la administración actuante podrá consultar o recabar los documentos salvo que el interesado se oponga a ello.

5.3.6 Publicaciones de actos administrativos

Cuando se publique un acto administrativo que contenga datos personales del afectado, se identificará al mismo mediante su nombre y apellidos, añadiendo cuatro cifras numéricas aleatorias del DNI o documento equivalente.

Cuando se trate de la notificación por medio de anuncios, se identificará al afectado exclusivamente mediante el número completo de su DNI o documento equivalente.

Cuando el afectado careciera de DNI, NIE, pasaporte o documento equivalente, se identificará al afectado únicamente mediante su nombre y apellidos.

En ningún caso debe publicarse el nombre y apellidos de manera conjunta con el número completo del documento de identidad.

5.3.7 Comunicación a sujetos privados

Los responsables públicos podrán comunicar los datos personales que les soliciten sujetos de derecho privado cuando concurra alguno de los dos siguientes elementos:

- a) Cuenten con el consentimiento de los afectados
- b) Aprecien que prevalece el interés legítimo del solicitante sobre los derechos y libertades de los afectados

5.3.8 Limitaciones al ejercicio de derechos

La disposición adicional decimocuarta deja en vigor las normas desarrolladas del artículo 13 de la Directiva 95/46/CE, y en particular los artículos 23 y 24 de la antigua LOPD de 1999. Por ellos, se limita el alcance de los derechos de acceso, rectificación o supresión para los tratamientos administrativos policiales si conlleva un riesgo para la seguridad pública o la defensa del Estado, la protección de derechos y libertades de terceros, o las necesidades de investigación que se estén realizando.

Los responsables de los ficheros de la Hacienda Pública podrán igualmente limitar o denegar el ejercicio de dichos derechos cuando los mismos obstaculicen actuaciones administrativas en caso de que el afectado este siendo investigado por el incumplimiento de obligaciones tributarias.

También se limitará el derecho a la información cuando afecte a la Defensa nacional, a la seguridad pública o a la persecución de infracciones penales.

5.3.9 Medidas de seguridad

Se estipula que el Real Decreto 3/2010, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica (ENS) será la referencia para el establecimiento de las medidas de seguridad sobre los tratamientos de datos personales por responsables o encargados públicos.

5.4 Consentimiento de los menores

El tratamiento de los datos personales de un menor de edad únicamente podrá fundarse en su consentimiento cuando sea mayor de 14 años (el Reglamento daba margen para fijar esta edad a cada Estado miembro entre los 13 y los 16 años).

El tratamiento de los datos de los menores de 14 años, fundado en el consentimiento, solo será lícito si consta el del titular de la patria potestad o tutela.

5.5 Personas fallecidas

El RGPD no aplicaba a la protección de datos personales de personas fallecidas, dejando en manos de los Estados establecer las normas relativas al tratamiento de los datos personales de estas.

La LOPDGDD habilita a los herederos o familiares de los fallecidos, para que puedan dirigirse al responsable o encargado para ejercer los derechos de acceso, rectificación o supresión, salvo que el fallecido lo hubiera prohibido expresamente.

5.6 Categorías especiales de datos

El RGPD prohíbe el tratamiento de categorías especiales de datos a menos que se cumplieran alguno de los supuestos enumerados, entre los que incluía el consentimiento expreso del interesado «excepto cuando el Derecho de la Unión o de los Estados miembros establezca que la prohibición mencionada en el apartado 1 no puede ser levantada por el interesado».

La LOPDGDD determina de hecho que, para tratar los datos de ideología, afiliación sindical, religión, orientación sexual, creencias u origen racial o étnico, no bastará el consentimiento del interesado para

levantar esa prohibición, de forma que sólo se podrán tratar si se cumple alguno de los restantes supuestos que establecía el RGPD en el artículo 6.1.

La LOPDGDD no incluye en este punto los datos biométricos y genéticos, que por tanto sí podrán tratarse con consentimiento del afectado.

5.7 Códigos de conducta y certificación

La ley desarrolla los códigos de conducta y certificación regulados por el RGPD.

Dichos códigos serán vinculantes para quienes se adhieran a los mismos, y podrán dotarse de mecanismos de resolución extrajudicial de conflictos. La AEPD y las autoridades autonómicas mantendrán registros de los códigos de conducta aprobados por ellas, accesibles por medios electrónicos.

En cuanto a la acreditación de instituciones de certificación, además de la propia AEPD, podrá realizarse por la Entidad Nacional de Acreditación (ENAC), en comunicación con la AEPD.

5.8 Procedimiento de reclamaciones

El título VIII de la ley establece el procedimiento que seguirá las AEPD en caso de recibir una reclamación por vulneración de la normativa de protección de datos.

Lo más destacado del procedimiento se resume en los siguientes puntos:

- Se establece un procedimiento unificado, tanto para la vulneración del ejercicio de los derechos de los apartados 15 a 22 del RGPD como para cualquier otra infracción del Reglamento (anteriormente se estipulaba un procedimiento diferente para la tutela de los derechos)
- Se incluye la coordinación transfronteriza como parte esencial en caso de afectar a varios Estados miembros de la UE, suspendiéndose los plazos en caso de consulta a otra autoridad o al Comité Europeo
- La comunicación con el responsable o su DPD pasa a ser un elemento del procedimiento en sus primeras fases, que puede permitir una resolución rápida y amistosa de la reclamación
- A la apertura del procedimiento sancionador le precederán potestativamente actuaciones previas de investigación, donde la autoridad de control podrá utilizar cualquiera de los poderes de inspección otorgados por el artículo 58.1 del RGPD

Además del procedimiento de investigación de reclamaciones, la AEPD también desarrolla su actividad de investigación por medio de planes de auditoría preventivas, que tienen por objeto el análisis del cumplimiento de un sector concreto de actividad, a partir de investigaciones sobre entidades pertenecientes al sector inspeccionado.

5.9 Régimen sancionador

La LOPDGDD realiza una categorización de las infracciones referidas en el RGPD, a efectos de calificarlas en leves, graves y muy graves, y de adjudicarlas un plazo de prescripción.

En cuanto a las sanciones previstas, además de añadir igualmente un plazo de prescripción en función de su gravedad, completa la lista de factores agravantes o atenuantes del RGPD.

5.9.1 Calificación de infracciones

El RGPD distribuía las infracciones en dos grupos según el umbral de sanción correspondiente: hasta 10 millones (o 2%) y hasta 20 millones (o 4%). La LOPDGDD distribuye esas mismas infracciones a su vez en tres grupos, como es habitual en la normativa nacional: leves, graves y muy graves, con el objeto de asignarles un plazo de prescripción diferenciado.

Se consideran infracciones muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los supuestos incluidos en el umbral superior (artículo 83.5 del RGPD), recordemos:

- Los principios básicos
- Derechos del interesado
- Transferencias internacionales

Así como cualquier vulneración del último supuesto del umbral superior (artículo 83.6 del RGPD):

- Incumplimiento de resoluciones de la autoridad de control

Se consideran infracciones graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los supuestos incluidos en el umbral inferior (artículo 83.4 del RGPD), que como ya sabemos eran:

- Obligaciones del responsable o encargado
- Obligaciones de organismos de certificación
- Obligaciones de organismos de supervisión de códigos de conducta

Se consideran infracciones leves y prescribirán al año las infracciones de carácter meramente formal de los supuestos incluidos en los artículos 83.4 y 83.5.

En todos los escalones, la LOPDGDD va más allá y en su interés por proporcionar seguridad jurídica, trata de particularizar las infracciones de uno y otro grupo, resultando en cerca de 70 tipificaciones, que pueden consultarse en los artículos 72, 73 y 74 de la ley.

Interrumpirá la prescripción de la infracción la iniciación, con conocimiento del interesado, del procedimiento sancionador.

5.9.2 Graduación de sanciones

La cuantía y umbrales de sanción ya están establecidos en el RGPD, por lo que la LOPDGDD se limita a extender la lista de factores agravantes o atenuantes proporcionados por el RGPD con los siguientes:

- El carácter continuado de la infracción
- La vinculación de la actividad del infractor con la realización de tratamientos de datos personales
- Los beneficios obtenidos como consecuencia de la infracción
- La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción
- La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente
- La afectación a los derechos de los menores
- Disponer, cuando no fuere obligatorio, de un delegado de protección de datos
- El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos

Se publicará en el BOE la información sobre el infractor, la infracción y la sanción impuesta por la AEPD, cuando la sanción supere el millón de euros y el infractor sea una persona jurídica.

5.9.3 Prescripción de las sanciones

Se establecen los siguientes plazos de prescripción para las sanciones, en función de la cuantía impuesta:

- Las sanciones de hasta 40.000 euros prescribirán al año
- Las sanciones entre 40.001 y 300.000 euros prescribirán a los dos años
- Las sanciones superiores a 300.000 euros prescribirán a los tres años

El plazo de prescripción de las sanciones comenzará a contarse desde el día siguiente a aquel en que sea ejecutable la resolución o haya transcurrido el plazo para recurrirla.

5.9.4 Administraciones Públicas

Cuando el responsable de la infracción sea un organismo público, la sanción correspondiente será siempre de apercibimiento, incluyendo en su caso la imposición de medidas correctivas. La autoridad de control también podrá proponer medidas disciplinarias. Tanto las actuaciones realizadas, como las resoluciones dictadas por la autoridad, se comunicarán al Defensor del Pueblo.

En ningún caso, por tanto, un organismo público podrá ser sancionado con una multa administrativa.

5.10 Derechos digitales

Los nuevos derechos digitales se incluyeron en la LOPD durante su tramitación parlamentaria, pero también podrían haberse incluido en su propia Ley Orgánica o en otra Ley Orgánica que estuviera en tramitación, porque no son exclusivos de la normativa de protección de datos ni emanan del Reglamento. Sí requerían de Ley Orgánica para su desarrollo por emanar del artículo 18.4 de la Constitución Española.

De los diecisiete derechos incluidos en este apartado, hay cinco de ellos que están relacionados con la protección de datos personales, si bien se pueden considerar particularidades de los derechos de los interesados ya incluidos en la normativa de protección de datos (RGPD artículos 12 a 22):

- Derecho a la intimidad frente al uso de dispositivos de videovigilancia y de grabación de sonidos en el lugar de trabajo
 - o Los empleadores habrán de informar con carácter previo a los trabajadores acerca de esta medida
- Derecho a la intimidad ante la utilización de sistemas de geolocalización en el ámbito laboral
 - o Con carácter previo, los empleadores habrán de informar a los trabajadores acerca de la existencia y características de estos dispositivos
- Protección de datos de los menores en Internet
 - o Protección especial en la publicación o difusión de sus datos personales a través de servicios de la sociedad de la información
- Derecho al olvido en búsquedas de Internet
 - o Los motores de búsqueda eliminarán los enlaces publicados que contuvieran información relativa a la persona cuando fuesen inadecuados, inexactos, no pertinentes, no actualizados o excesivos
- Derecho al olvido en servicios de redes sociales y servicios equivalentes
 - o Toda persona tiene derecho a que sean suprimidos, a su simple solicitud, los datos personales que hubiese facilitado para su publicación por servicios de redes sociales

Los otros doce derechos son propios de la sociedad digital, pero no de la protección de datos. No obstante, se listan por completar el marco jurídico y para mayor conocimiento del lector:

- Derecho a la neutralidad de Internet
 - o Derecho a una oferta transparente de servicios sin discriminación por motivos técnicos o económicos
- Derecho de acceso universal a Internet
 - o Se garantizará un acceso universal, asequible, de calidad y no discriminatorio para toda la población
- Derecho a la seguridad digital
 - o Derecho a la seguridad de las comunicaciones que transmitan y reciban a través de Internet
- Derecho a la educación digital
 - o El sistema educativo garantizará la plena inserción del alumnado en la sociedad digital y el aprendizaje de un uso de los medios digitales
- Protección de los menores en Internet
 - o Se garantizará el adecuado desarrollo de su personalidad y se preservará su dignidad y sus derechos fundamentales
- Derecho de rectificación en Internet
 - o Los responsables de redes sociales adoptarán protocolos para posibilitar el ejercicio del derecho de rectificación ante los usuarios que difundan contenidos que atenten contra el derecho al honor, la intimidad personal y familiar en Internet y el derecho a comunicar o recibir libremente información veraz
- Derecho a la actualización de informaciones en medios de comunicación digitales
 - o Se incluirá un aviso de actualización visible junto a las noticias que conciernan a un interesado cuando la información contenida en la noticia original no refleje su situación actual
- Derecho a la intimidad y uso de dispositivos digitales en el ámbito laboral
 - o Los trabajadores tendrán derecho a la protección de su intimidad en el uso de los dispositivos digitales puestos a su disposición por su empleador
- Derecho a la desconexión digital en el ámbito laboral
 - o Se garantizará, fuera del tiempo de trabajo legal o convencionalmente establecido, el respeto del tiempo de descanso, permisos y vacaciones, así como de la intimidad personal y familiar
- Derechos digitales en la negociación colectiva
 - o Los convenios colectivos podrán establecer garantías adicionales en relación con estos derechos digitales
- Derecho de portabilidad en servicios de redes sociales y servicios equivalentes
 - o Los usuarios de servicios de redes sociales tendrán derecho a recibir y transmitir los contenidos que hubieran facilitado a los prestadores de dichos servicios
- Derecho al testamento digital
 - o Las personas vinculadas al fallecido por razones familiares, así como sus herederos podrán dirigirse a los prestadores de servicios de la sociedad de la información al objeto de acceder a dichos contenidos

5.11 Conclusión

El RGPD no deja el margen de maniobra nacional que permite la trasposición de las directivas. Por tanto, la LOPDGDD solo complementa o desarrolla algunos artículos del RGPD para los que este daba lugar.

Hay disposiciones del RGPD que expresamente son un mandato para que los Estados adopten normas de aplicación que las completen o detallen. El ejemplo más claro de este tipo de disposiciones es el

que tiene que ver con las autoridades de supervisión. El RGPD define sus características generales, pero pide a los Estados que adopten normas en las que se precise cuál de las posibles opciones que ofrece eligen.

Por otra parte, hay disposiciones en que la regulación nacional es prácticamente condición indispensable para que el RGPD pueda aplicarse. Es el caso, entre otros, de los plazos de prescripción de las infracciones y sanciones.

Una tercera posibilidad es que los Estados hagan uso de las autorizaciones del RGPD para regular determinadas materias en el plano nacional. Un ejemplo, es el de la edad mínima para que los menores pueden otorgar consentimiento y sus datos puedan ser tratados sin necesitar la autorización de sus padres o tutores. El RGPD fija esa edad en 16 años. Sin embargo, permite a los Estados miembros que la reduzcan hasta un límite mínimo de 13.

En definitiva, aunque el grueso de las disposiciones del RGPD sí produce sus efectos y son aplicables directamente por los operadores jurídicos en toda la UE, también incluye otras en que su regulación se verá precisada o complementada por normativa nacional. Esto es lo que hace la LOPDGDD, que precisamente por su naturaleza de complemento del Reglamento europeo, ya no puede entenderse como una ley integral que cubra toda la normativa de protección de datos de arriba abajo, sino que de hecho es una ley que no se puede comprender ni aplicar correctamente sin el sustento que proporciona el RGPD.

6 El Delegado de Protección de Datos

6.1 Introducción

La figura del Delegado de Protección de Datos (DPD o también comúnmente DPO, por sus siglas en inglés) la crea el RGPD como un elemento fundamental de la capacidad de responder proactivamente en el cumplimiento de la normativa. La LOPDGDD complementa este punto añadiendo una lista adicional y concreta de sujetos obligados a tenerlo.

Los siguientes apartados se dedican a explorar el carácter y funciones de esta figura, que finalmente se particularizará para los responsables públicos.

6.2 Sujetos obligados

El RGPD requiere designar un Delegado de Protección de Datos para responsables y encargados que se encuentren en alguno de estos tres supuestos:

- a) Autoridades u organismos públicos (excepto los tribunales en ejercicio de su función judicial)
- b) Sus actividades principales consistan en operaciones de tratamiento que exigen observación sistemática de interesados a gran escala
- c) Sus actividades principales consistan en tratar a gran escala categorías especiales de datos, o relativos a condenas e infracciones penales

Vuelve a ser determinante el concepto de *gran escala*, que veíamos al explicar las evaluaciones de impacto.

Y en todo caso, la LOPDGDD determina que deben estar obligadas las siguientes entidades:

- Colegios profesionales
- Centros docentes
- Entidades de redes y servicios de comunicaciones electrónicas cuando traten datos personales a gran escala
- Prestadores de servicios de la sociedad de la información cuando elaboren a gran escala perfiles de usuario
- Entidades de crédito (bancos, cajas de ahorro, cooperativas de crédito, el ICO)
- Establecimientos financieros
- Aseguradoras y reaseguradoras
- Empresas de inversión en el mercado de valores
- Distribuidoras y comercializadoras de gas y energía eléctrica
- Responsables de ficheros comunes de morosidad y de blanqueo de capitales y financiación del terrorismo
- Entidades de publicidad y prospección comercial, cuando elaboren perfiles
- Centros sanitarios, salvo los profesionales que ejerzan a título individual
- Entidades que emitan informes comerciales de personas físicas
- Operadores de juego
- Empresas de seguridad
- Federaciones deportivas cuando traten datos de menores

Además de, voluntariamente, cualquier empresa u organismo que lo estime conveniente.

6.3 Relación laboral

El DPD podrá ser un empleado del responsable o encargado, o bien ser externo y desarrollar sus tareas por medio de un contrato de servicios. La LOPDGDD admite que el DPD pueda ser una persona física o jurídica. En todo caso, sus datos de contacto deben ser públicos y comunicarse a la autoridad de control. En nuestro país, la AEPD mantiene un registro de DPDs público y consultable en su sede electrónica.

El DPD está especialmente protegido por el Reglamento, que especifica que debe garantizarse su autonomía (no puede recibir instrucciones de nadie en relación a sus tareas), no puede ser despedido o penalizado por desarrollar su trabajo, y además estipula que rendirá cuentas directamente al más alto nivel jerárquico.

El DPD puede tener otras responsabilidades además de la propia de DPD dentro de la organización, pero estas otras responsabilidades no deben ser incompatibles. Por ejemplo, debería de forma general evitarse que un director TIC, o un responsable de seguridad, fueran nombrados DPD, puesto que esto podría generar conflictos de interés, y vulnerar el principio de independencia y autonomía que debe tener el DPD. El DPD actúa como asesor y supervisor interno, por lo que ese puesto no puede ser ocupado por personas que también tengan tareas que impliquen decisiones sobre la existencia de tratamientos de datos o sobre el modo en que van a ser tratados los datos.

6.4 Funciones

El DPD debe tener, al menos, las siguientes funciones que le atribuye el RGPD:

- Informar y asesorar al responsable o encargado de las obligaciones que les impone la normativa de protección de datos
- Supervisar el cumplimiento de la normativa
- Asesorar acerca de las evaluaciones de impacto y supervisar su aplicación
- Cooperar con la autoridad de control
- Actuar de punto de contacto con la autoridad de control para cuestiones relativas al tratamiento, incluida la consulta previa en caso de evaluaciones de impacto de riesgo alto, así como realizar consultas sobre cualquier otro asunto

La LOPDGDD añade que, en caso de reclamación contra el responsable ante una autoridad de control, la autoridad podrá dirigirse al DPD y trasladarle la reclamación a fin de que este responda y/o resuelva la situación antes de la apertura del correspondiente procedimiento.

Para cumplir las funciones, el Reglamento establece que el DPD debe ser designado «atendiendo a sus cualidades profesionales y, en particular, a sus conocimientos especializados del Derecho y la práctica en materia de protección de datos». Los conocimientos en tecnologías también se antojan imprescindibles para el correcto ejercicio de sus funciones.

6.5 El DPD en las Administraciones Públicas

Como se ha enunciado en el apartado anterior, cuando el tratamiento lo efectúe una autoridad u organismo público en calidad de responsable o encargado, se debe designar necesariamente un DPD.

Aunque en general las disposiciones y funciones que indica el RGPD aplican por igual a entidades públicas que privadas, sí existen algunas características que se pueden señalar como particulares para el sector público:

- a) El RGPD prevé que se pueda designar un único delegado de protección de datos para varios de estas autoridades u organismos públicos, teniendo en cuenta su estructura organizativa y tamaño
- Esta previsión está directamente relacionada con una de las primeras cuestiones a resolver en relación con los DPD en el ámbito público, que es la de determinar cuál va a ser su lugar en las organizaciones administrativas
 - Con carácter general, sería posible designar un único DPD para un ministerio, consejería o ayuntamiento. Al mismo tiempo, no parece aconsejable que ese único DPD actúe respecto de grandes unidades u órganos con entidad y tareas claramente diferenciadas, por mucho que orgánicamente puedan depender de un departamento ministerial, consejería o ayuntamiento (por ejemplo, la Dirección General de Tráfico con respecto al Ministerio del Interior)
 - Por otra parte, y dadas las funciones del DPD, su adscripción dentro de la estructura de la organización debe hacerse a órganos o unidades con competencias y funciones de carácter horizontal
 - Asimismo, el nivel del puesto de trabajo debe ser el adecuado para poder relacionarse directamente con la dirección del órgano u organismo en el que desempeñe sus funciones
- b) El RGPD prevé que el DPD podrá desarrollar su actividad a tiempo completo o a tiempo parcial y también que podrá formar parte de la plantilla del responsable o del encargado del tratamiento o desempeñar sus funciones en el marco de un contrato de servicios
- En órganos, organismos o entes de gran tamaño en que exista un único DPD lo habitual será que desempeñe sus funciones a tiempo completo
 - Es igualmente posible que el DPD formalmente nombrado esté respaldado por una unidad específicamente dedicada a la protección de datos
 - En entidades de menor tamaño será posible que el DPD compagine sus funciones con otras (si este es el caso, debe tenerse en cuenta la necesidad de evitar conflictos de intereses entre las diversas ocupaciones)
- c) El RGPD ofrece la posibilidad de que se contraten externamente las funciones de DPD
- Esta opción puede ser utilizada en determinados casos, como podría ser el de pequeños municipios que se benefician de un servicio que ofrezca una diputación provincial o una comunidad autónoma o, incluso, que puedan optar por los servicios de entidades privadas (no hay una restricción a este respecto en el Reglamento, aunque el hecho de que sea una entidad privada debería considerarse con cautela, puesto que podría implicar restricciones a la hora de supervisar tratamientos y acceder a los datos personales)
- d) Por último, la provisión de los puestos de trabajo de DPD requerirá la selección de empleados públicos que reúnan los requisitos necesarios y, en especial, los conocimientos especializados en derecho y práctica la protección de datos que el RGPD exige
- Será necesario desarrollar una labor de formación de posibles candidatos a ocupar por primera vez los puestos de DPD en todos los niveles de la Administración y establecer con carácter permanente actividades de formación en protección de datos para empleados públicos que deseen especializarse en la materia y optar eventualmente a ocupar los puestos de DPD

6.6 Conclusión

El Reglamento introduce la figura del DPD como una de las medidas que, junto con otras como la necesidad de adoptar un enfoque basado en el riesgo, la elaboración del registro de actividades de tratamiento, la adopción de medidas de protección de datos desde el diseño y por defecto, el establecimiento de las adecuadas medidas de seguridad, la notificación de brechas de seguridad, o la evaluación de impacto sobre la privacidad, implementan el principio de responsabilidad proactiva.

Este principio de responsabilidad proactiva y el enfoque basado en el riesgo son dos de los mayores retos que se recogen en el Reglamento europeo y que requieren un mayor esfuerzo por parte de los

responsables y encargados del tratamiento y en los que el DPD debe jugar un papel fundamental a la hora de asesorar al responsable y supervisar el cumplimiento de la normativa de protección de datos dentro de la organización.

Es por tanto un elemento central para cumplir con el objetivo de facilitar el cumplimiento del marco normativo de protección de datos mediante la aplicación de instrumentos de rendición de cuentas y su papel como intermediario entre las partes interesadas.

7 La Agencia Española de Protección de Datos

7.1 Introducción

La AEPD es la autoridad pública independiente nacional establecida con arreglo a lo dispuesto en el artículo 51 del RGPD. Es su responsabilidad «supervisar la aplicación del Reglamento con el fin de proteger los derechos y las libertades fundamentales de las personas físicas en lo que respecta al tratamiento y de facilitar la libre circulación de datos personales en la Unión».

Es la autoridad de control nacional que representa a todas las autoridades de protección de datos españolas en el Comité Europeo de Protección de Datos, y en los grupos de trabajo que dependen del Comité.

El RGPD además protege la independencia de las autoridades de control, que deben ser ajenos a toda influencia externa y no admitir ninguna instrucción.

Por último, el RGPD dispone que cada Estado miembro establezca por ley los elementos constituyentes de su autoridad, lo cual en nuestro país se realiza en el título VII de la LOPDGDD.

7.2 Régimen jurídico

La AEPD es una autoridad administrativa independiente de ámbito estatal, de las previstas en la Ley 40/2015 de Régimen Jurídico del Sector Público, con personalidad jurídica y plena capacidad pública y privada, que actúa con plena independencia de los poderes públicos en el ejercicio de sus funciones, relacionándose con el Gobierno a través del Ministerio de Justicia.

La Agencia se rige por lo dispuesto en el RGPD, la LOPDGDD y sus futuras disposiciones de desarrollo. Y supletoriamente, por las normas citadas en el artículo 110.1 de la Ley 40/2015, que hacen referencia al régimen jurídico de las autoridades administrativas independientes de ámbito estatal.

El Gobierno, a propuesta de la Agencia, aprobará su Estatuto mediante real decreto. Los plazos para la aprobación de un nuevo Estatuto de conformidad con la LOPDGDD deberán esperar a la formación de nuevo Gobierno después de las elecciones generales de 2019.

7.3 Régimen presupuestario y de personal

La AEPD elabora y aprueba su presupuesto, que remite al Gobierno para su integración en los Presupuestos Generales del Estado.

La Agencia cuenta con las asignaciones que se establecen con cargo a los Presupuestos Generales del Estado, los bienes y valores que constituyan su patrimonio y los ingresos, ordinarios y extraordinarios, derivados del ejercicio de sus actividades, incluidos los derivados del ejercicio de las potestades sancionadoras.

El personal al servicio de la Agencia será funcionario o laboral y se regirá por lo previsto en el texto refundido de la Ley del Estatuto Básico del Empleado Público. La Agencia elaborará y aprobará su propia relación de puestos de trabajo, en el marco de los criterios establecidos por el Ministerio de Hacienda, respetando el límite de gasto de personal establecido en el presupuesto.

Los funcionarios que desarrollen actividades de investigación tendrán la consideración de agentes de la autoridad en el ejercicio de sus funciones, y estarán obligados a guardar secreto sobre las informaciones que conozcan con ocasión de dicho ejercicio.

7.4 La Presidencia

La Presidencia de la AEPD y su Adjunto serán nombrados por el Gobierno, a propuesta del Ministerio de Justicia, entre personas de reconocida competencia profesional, en particular en materia de protección de datos.

El Gobierno remitirá al Congreso de los Diputados una propuesta de Presidencia y Adjunto que deberá ser ratificada por la Comisión de Justicia en votación pública por mayoría de tres quintos de sus miembros en primera votación o, de no alcanzarse esta, por mayoría absoluta en segunda votación. En este último supuesto, los votos favorables deberán proceder de Diputados pertenecientes, al menos, a dos grupos parlamentarios diferentes.

Ambos ejercerán sus funciones con plena independencia y objetividad y no estarán sujetos a instrucción alguna en su desempeño. Les será aplicable la legislación reguladora del ejercicio del alto cargo de la Administración General del Estado.

El mandato de la Presidencia y del Adjunto tendrá una duración de cinco años y podrá ser renovado para otro período de igual duración. Solo cesarán antes de la expiración de su mandato, a petición propia o por separación acordada por el Consejo de Ministros, por:

- a) Incumplimiento grave de sus obligaciones
- b) Incapacidad sobrevenida para el ejercicio de su función
- c) Incompatibilidad
- d) Condena firme por delito doloso

Los actos y disposiciones dictados por la Presidencia de AEPD ponen fin a la vía administrativa, siendo recurribles, directamente, ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional.

7.5 Estructura orgánica

El actual estatuto de la AEPD, que continúa vigente en lo que no se oponga al Título VIII de la LOPDGDD, establece una estructura basada en 3 órganos: el Registro General de Protección de Datos, la Inspección de Datos y la Secretaría General. Esta estructura se ve afectada por las novedades introducidas por el RGPD, como la supresión de la obligación de registrar los ficheros, y que, en consecuencia, habrá de replantearse en el estatuto de la AEPD que se acabe adoptando.

Además, la AEPD cuenta con una Unidad de Apoyo al director, un Gabinete Jurídico, un Departamento de Relaciones Internacionales y una Unidad de Estudios y Evaluación Tecnológica.

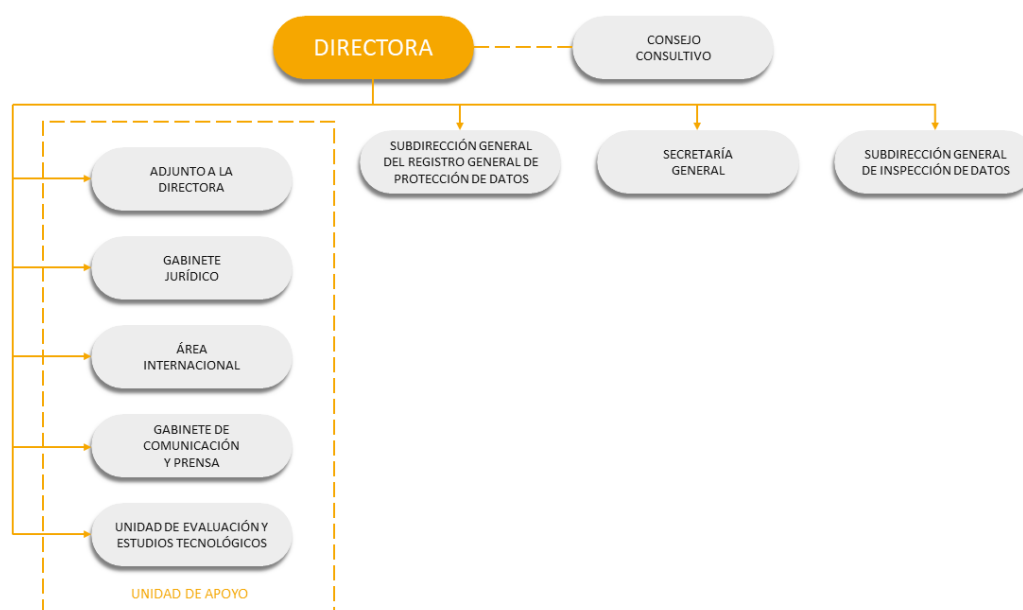


Figura 11 Organigrama de la AEPD publicado en su página web

7.6 El Consejo Consultivo

La Presidencia de la Agencia estará asesorada por un Consejo Consultivo compuesto por los siguientes miembros:

- Un Diputado
- Un Senador
- Un representante designado por el Consejo General del Poder Judicial
- Un representante de la Administración General del Estado con experiencia en la materia
- Un representante de cada Comunidad Autónoma que haya creado una Autoridad de protección de datos autonómica
- Un experto propuesto por la Federación Española de Municipios y Provincias
- Un experto propuesto por el Consejo de Consumidores y Usuarios
- Dos expertos propuestos por las Organizaciones Empresariales
- Un representante de los profesionales de la protección de datos y de la privacidad
- Un representante de los organismos o entidades de supervisión y resolución extrajudicial de conflictos
- Un experto propuesto por la Conferencia de Rectores de las Universidades Españolas
- Un representante de las organizaciones que agrupan a los Consejos Generales, Superiores y Colegios Profesionales de ámbito estatal de las diferentes profesiones colegiadas
- Un representante de los profesionales de la seguridad de la información
- Un experto en transparencia y acceso a la información pública
- Dos expertos propuestos por las organizaciones sindicales

El Consejo Consultivo se reunirá cuando así lo disponga la Presidencia de la Agencia y, en todo caso, una vez al semestre.

Las decisiones tomadas por el Consejo Consultivo no tendrán en ningún caso carácter vinculante.

7.7 Deber de colaboración

Las Administraciones Públicas, incluidas las tributarias y de la Seguridad Social, estarán obligadas a proporcionar a la AEPD los datos, informes, antecedentes y justificantes necesarios para llevar a cabo su actividad de investigación.

Cuando no haya podido realizar la identificación por otros medios, la Agencia podrá recabar de los operadores que presten servicios de comunicaciones electrónicas disponibles al público y de los prestadores de servicios de la sociedad de la información los datos que obren en su poder y que resulten imprescindibles para la identificación del presunto responsable.

7.8 Potestades de regulación

La Presidencia de la Agencia podrá dictar disposiciones que fijen los criterios a que responderá la actuación de esta autoridad, que se denominarán Circulares. Las circulares serán obligatorias una vez publicadas en el Boletín Oficial del Estado.

7.9 Autoridades autonómicas

Las autoridades autonómicas podrán ejercer las funciones y poderes otorgados por el RGPD en el ámbito de su Comunidad Autónoma cuando se refieran a:

- Tratamientos realizados por responsables del sector público en su ámbito territorial
- Tratamientos realizados por personas físicas o jurídicas para el ejercicio de funciones públicas competencia de la Administración autonómica
- Tratamientos previstos en sus Estatutos de Autonomía

Es decir, siempre será competencia de la AEPD en exclusiva los tratamientos de titularidad privada, independientemente del territorio dónde se encuentre el establecimiento del responsable.

Las autoridades autonómicas también podrán emitir circulares en su ámbito de actuación con los mismos efectos que los previstos para las de la AEPD.

Actualmente, existen dos autoridades autonómicas, la Autoridad Catalana de Protección de Datos y la Agencia Vasca de Protección de Datos. El Consejo de Transparencia y Protección de Datos de Andalucía, creado en 2014, aún no ha asumido de forma efectiva las competencias de protección de datos que le otorga la normativa autonómica, por lo que sus competencias siguen siendo ejercidas por la AEPD a día de hoy.

7.10 Conclusión

La AEPD es la autoridad de control independiente que vela por el cumplimiento de la legislación en materia de protección de datos, que se rige por lo dispuesto en la propia LOPDGDD y en su Estatuto.

Además, y en virtud de la previsión contenida en el artículo 57 de la LOPDGDD, existen las autoridades de control autonómicas que ejercen sus funciones en relación con su respectivo sector público y que son la Agencia Vasca de Protección de Datos, la Autoridad Catalana de Protección de Datos, y el Consejo de Transparencia y Protección de Datos de Andalucía (pendiente de asumir las competencias de protección de datos).

8 RESUMEN ESQUEMÁTICO

- **Introducción**
 - Presentación de los contenidos del tema
- **El derecho a la protección de datos**
 - Historia
 - Marco actual
 - RGPD
 - LOPDGDD
 - LSSI
 - LGT
 - Directiva datos penales
 - Directiva organismos UE
 - Conceptos básicos de la protección de datos
- **El Reglamento General de Protección de Datos**
 - Ámbito
 - Sujetos obligados
 - Materias incluidas
 - Territorio
 - Licitud del tratamiento
 - Bases legales
 - Consentimiento
 - Contrato
 - Obligación legal
 - Intereses vitales
 - Interés público o poderes públicos
 - Intereses legítimos que prevalezcan
 - El consentimiento
 - Libre
 - Específico
 - Informado
 - Inequívoco
 - Individualizado
 - Retirable
 - Mayor control del interesado sobre sus datos
 - Principios
 - Licitud, lealtad y transparencia
 - Limitación de la finalidad
 - Minimización de datos
 - Exactitud
 - Plazo de conservación
 - Integridad y confidencialidad
 - Responsabilidad proactiva
 - Derechos (PILDORAS)
 - Información
 - Acceso
 - Rectificación
 - Oposición
 - Supresión
 - Limitación
 - Portabilidad
 - Decisiones individuales automatizadas
 - Datos de categoría especial
 - Etnia o raza
 - Opiniones políticas
 - Convicciones religiosas o filosóficas
 - Afiliación sindical

- Genéticos
 - Biométricos
 - Salud
 - Vida u orientación sexual
- Responsabilidad proactiva
 - Desde el diseño
 - Por defecto
 - Registro de actividades
 - Análisis de riesgos
 - Medidas de seguridad
 - Evaluación de impacto y consulta previa
 - DPD
 - Notificación de brechas
 - Códigos de conducta
- Transferencias de datos
- Cooperación y coherencia transfronteriza
 - Ventanilla única
 - Asistencia mutua
 - Coherencia
 - Comité Europeo
- Régimen sancionador
 - Sujetos afectados
 - Responsables
 - Encargados
 - Representantes de estos
 - Entidades de certificación
 - Supervisores de códigos de conducta
 - Poderes de investigación
 - Poderes correctivos
 - Ordenar adaptaciones
 - Ordenar atención de derechos
 - Ordenar rectificación, supresión o limitación de los datos
 - Advertencia
 - Apercibimiento
 - Limitación
 - Multa
 - Multas
 - Hasta 10M o 2%
 - Obligaciones del responsable o encargado
 - Obligaciones de organismos de certificación
 - Obligación de organismos de supervisión de códigos
 - Hasta 20M o 4%
 - Principios básicos
 - Derechos del interesado
 - Transferencias internacionales
 - Incumplimiento de resoluciones de la autoridad de control
- **Política de protección de datos**
 - Datos del responsable y DPD
 - Finalidades
 - Plazo de conservación
 - Ejercicio de derechos
 - Cesiones
 - Obligatoriedad
 - Perfiles y decisiones automatizadas
 - Transferencias
- **Ley Orgánica de Protección de datos personales**
 - Disposiciones sobre tratamientos concretos
 - Datos de contacto de empleados y autónomos
 - Sistemas de información crediticia
 - Operaciones mercantiles

- Videovigilancia
 - Sistemas de exclusión publicitaria
 - Sistemas de denuncias internas
 - Función estadística pública
 - Archivo de interés público
 - Infracciones y sanciones administrativas
 - Actividades electorales
 - Datos de salud
- Tratamientos por responsables públicos
 - Lista de responsables públicos
 - Bases de legitimación comunes
 - Obligación legal
 - Interés público o potestades públicas
 - Potestad de verificación
 - Registros de personal
 - Documentos aportados por los interesados
 - Publicación de actos
 - Comunicación a sujetos privados
 - Limitaciones al ejercicio de derechos
 - Medidas de seguridad
- Consentimiento de menores
- Datos de personas fallecidas
- Categorías especiales de datos
- Códigos de conducta y certificación
- Procedimiento de reclamaciones
- Régimen sancionador
 - Calificación de infracciones
 - Graduación de sanciones
 - Prescripción de sanciones
 - Régimen para las AAPP
- Derechos digitales
 - Videovigilancia en el trabajo
 - Geolocalización en el ámbito laboral
 - Datos de menores en Internet
 - Derecho al olvido en búsquedas
 - Derecho al olvido en redes
 - Otros 12 que trascienden el ámbito de la protección de datos
- **El Delegado de Protección de Datos**
 - Sujetos obligados
 - Organismos públicos
 - Observación sistemática a gran escala
 - Categorías especiales a gran escala
 - En todo caso, entidades recogidas en la LOPDGDD
 - Relación laboral
 - Funciones
 - Administraciones Públicas
- **La Agencia Española de Protección de Datos**
 - Régimen jurídico
 - Régimen presupuestario
 - La Presidencia
 - Estructura orgánica
 - Consejo consultivo
 - Deber de colaboración
 - Potestades de regulación
 - Autoridades autonómicas

9 GLOSARIO

- AEPD: Agencia Española de Protección de Datos
- AGE: Administración General del Estado
- CCAA: Comunidades Autónomas
- CEPD: Comité Europeo de Protección de Datos
- DPD: Delegado de Protección de Datos
- EEE: Espacio Económico Europeo
- EIDP: Evaluación de Impacto sobre los Datos Personales
- GT29: El Grupo de Trabajo del artículo 29 (es el órgano consultivo independiente de la UE, creado en virtud del artículo 29 de la Directiva 95/46/CE, que se ha ocupado de cuestiones relacionadas con la protección de la privacidad y los datos personales hasta el 25 de mayo de 2018)
- LOPDGDD: Ley Orgánica de Protección de Datos y Garantía de los Derechos Digitales
- LORTAD: Ley Orgánica de Regulación del Tratamiento Automatizado de los Datos de Carácter Personal
- LSSI: Ley de Servicios de la Sociedad de la Información y de comercio electrónico
- RGPD: Reglamento General de Protección de Datos
- UE: Unión Europea

10 TEST

10.1 PREGUNTAS DE TEST

- 1) ¿En qué fecha entró en vigor el Reglamento General de Protección de Datos (RGPD)?
 - a) El 1 de enero de 2018
 - b) El 1 de enero de 2019
 - c) El 24 de mayo de 2016
 - d) El 25 de mayo de 2018
- 2) ¿En qué países resulta de aplicación el RGPD?
 - a) En todos los países del EEE
 - b) En toda la UE menos el Reino Unido
 - c) En la UE
 - d) En los países de la UE que lo han ratificado
- 3) De los siguientes datos, ¿cuál *no* es un dato personal según la interpretación del RGPD?
 - a) Los resultados de una encuesta de voto separada por sexos y franjas de edad, en un pueblo donde sólo hay tres varones jóvenes
 - b) Una huella dactilar
 - c) Las páginas webs del historial de visitas
 - d) El nombre de las calles de un municipio
- 4) ¿Cuál de los siguientes *no* es un objetivo del RGPD?
 - a) Proporcionar un mismo nivel de protección en todos los Estados Miembros
 - b) Facilitar la venta de datos personales de personas físicas
 - c) Desarrollar la economía digital en la UE
 - d) La libre circulación de los datos personales en la UE con garantías
- 5) ¿Cuál de los siguientes tratamientos *no* requiere el cumplimiento de derechos y obligaciones del RGPD?
 - a) La agenda de contactos de un móvil personal
 - b) Las fotos colgadas en un perfil público en redes sociales
 - c) Los visitantes de una página web, identificados por su IP, pero no por su nombre
 - d) Los historiales de los pacientes de una clínica dental
- 6) ¿Cuál de los siguientes tratamientos de datos personales de clientes entra dentro del ámbito territorial del RGPD?
 - a) El de una empresa americana sin establecimientos en Europa, que ofrece globalmente recambios mecánicos a través de su página web, y que realiza envíos a direcciones en España
 - b) Un productor de naranjas establecido en España que vende únicamente a clientes japoneses
 - c) Ambos
 - d) Ninguno
- 7) ¿Cuáles son bases que legitiman un tratamiento de datos personales?
 - a) Siempre que se desee y se registre en la AEPD
 - b) El consentimiento tácito o por omisión

- c) Para cumplir una misión de interés público
 - d) Para proteger una vivienda o intereses familiares
- 8) ¿Cuál de los siguientes consentimientos se considera válido?
- a) Una red social solicita consentimiento para explotar los datos con fines comerciales, y de lo contrario impide usar el servicio
 - b) Un establecimiento solicita un consentimiento único para tratar los datos con todas las finalidades indicadas (todo o nada)
 - c) Una compañía de telecomunicaciones informa convenientemente en una carta, y asume que si no se responde, se está aceptando el tratamiento
 - d) Ninguno de ellos
- 9) ¿Cuál *no* es uno de los principios relativos al tratamiento indicados en el artículo 5 del RGPD?
- a) Limitación de la finalidad
 - b) Exactitud
 - c) Personalización
 - d) Integridad y confidencialidad
- 10) ¿Cuál de los principios del RGPD se estaría incumpliendo al tratar indefinidamente datos que no son necesarios para la finalidad declarada?
- a) Minimización de datos
 - b) Limitación del plazo de conservación
 - c) Las dos anteriores
 - d) Si es para mejorar el servicio, ninguno
- 11) ¿Cuáles son los derechos del interesado recogidos en el Capítulo III del RGPD?
- a) Acceso, Rectificación, Cancelación, Oposición
 - b) Acceso, Rectificación, Supresión, Oposición, no ser objeto de Decisiones Individuales Automatizadas, Limitación del tratamiento
 - c) Información, Acceso, Rectificación, Supresión, Oposición, no ser objeto de Decisiones Individuales Automatizadas, Limitación del tratamiento, Reclamación
 - d) Información, Acceso, Rectificación, Supresión, Oposición, no ser objeto de Decisiones Individuales Automatizadas, Limitación del tratamiento, Portabilidad
- 12) ¿Cuál de los siguientes elementos no forma parte del derecho de información del RGPD?
- a) Finalidades del tratamiento
 - b) Transferencias previstas a terceros países
 - c) Identidad y datos del responsable y, en su caso, DPD
 - d) Plazo de reclamación ante la autoridad de control
- 13) ¿Cuál de las siguientes es una categoría especial de datos según el RGPD?
- a) Datos financieros y tributarios
 - b) Opiniones políticas
 - c) Datos de menores
 - d) Datos laborales
- 14) ¿Qué supone para un responsable asumir el principio de responsabilidad proactiva que introduce el RGPD? (entre otras cosas)
- a) Obligación de registrar el fichero en la autoridad de control
 - b) Realizar un análisis de riesgo de los tratamientos

- c) Asumir la responsabilidad en caso de sanción
 - d) Indemnizar a los afectados por una infracción cuando hay una resolución firme de la autoridad de control
- 15) ¿De qué precepto del RGPD sería un ejemplo la seudonimización?
- a) Privacidad por defecto
 - b) Privacidad desde el diseño
 - c) Minimización de datos
 - d) a) y b)
- 16) ¿Cuál es el momento idóneo para definir las medidas de seguridad de un nuevo tratamiento de datos personales basado en las TIC?
- a) Cuando se diseña el proyecto
 - b) Una vez implementado el proyecto
 - c) En la fase de pruebas
 - d) En paralelo al proyecto, de forma que no retrase la implantación
- 17) ¿Quién de los siguientes está obligado a registrar las actividades del tratamiento en la Autoridad de Control?
- a) Nadie
 - b) Los encargados del tratamiento de menos de 250 empleados
 - c) Todas las empresas y organismos que traten datos personales
 - d) Los responsables del tratamiento de más de 250 empleados
- 18) Una empresa que vaya a lanzar al mercado una app móvil dirigida a menores que permita hacer perfiles de comportamiento, ¿qué pasos debería dar de forma previa al lanzamiento?
- a) Hacer un análisis de riesgos
 - b) Hacer un análisis de riesgos y una evaluación de impacto
 - c) Hacer un análisis de riesgos, una evaluación de impacto y una consulta previa
 - d) Hacer un análisis de riesgos, una evaluación de impacto, y, en función del resultado, una consulta previa
- 19) ¿Cuál de las siguientes empresas u organismos debe necesariamente nombrar un DPD?
- a) Un banco
 - b) Un hospital
 - c) Un sindicato mayoritario
 - d) Todos los anteriores
- 20) Una empresa que ha detectado una brecha de seguridad que afecta a datos personales, pero que necesita tiempo para conocer el alcance de la misma...
- a) Debe realizar una primera notificación antes de 72 horas desde que ocurrió, a menos que no observe riesgo para los afectados, y completarla una vez tenga toda la información
 - b) En todo caso debe comunicar la brecha a la autoridad de control antes de 72 horas desde que tuvo constancia
 - c) Debe comunicar la brecha a la autoridad de control antes de 24 horas desde que tuvo constancia, sólo si constituye un riesgo para los afectados
 - d) Debe recopilar toda la información antes de comunicarla
- 21) En caso de que un tratamiento afecte a ciudadanos de varios países de la UE, ¿qué autoridad de control sería competente?

- a) La que reciba la reclamación
 - b) La del establecimiento principal del responsable o encargado
 - c) Todas las que tengan afectados en su país
 - d) Todas las que tengan establecimientos del responsable o encargado en su país
- 22) ¿Cuál de los siguientes *no* es un poder correctivo de las autoridades de control?
- a) Sancionar con una multa
 - b) Imponer una limitación del tratamiento
 - c) Bloquear los fondos financieros
 - d) Ordenar la atención de los derechos
- 23) ¿En qué caso puede hacerse una transferencia de datos a terceros países sin autorización de la autoridad de control?
- a) Cuando existan normas corporativas vinculantes y se haga entre empresas de una misma organización empresarial
 - b) Cuando se incluyan las cláusulas específicas en el contrato con el destinatario
 - c) Cuando se transfiera a un responsable en Estados Unidos
 - d) Cuando haya unas disposiciones para ello en un acuerdo administrativo
- 24) ¿Cuál de los siguientes responsables está obligado a nombrar un DPD?
- a) Un organismo público, aunque no trate datos personales
 - b) Una pequeña start-up, que recoge datos personales de comportamiento online de forma masiva
 - c) Una empresa que gestiona datos de trabajadores y proveedores
 - d) Un autónomo colegiado
- 25) ¿Qué información debería figurar en una política de protección de datos?
- a) Las posibles cesiones a terceros
 - b) Las posibles transferencias internacionales a terceros países
 - c) Las finalidades de los tratamientos
 - d) Todas las anteriores
- 26) De acuerdo con la LOPDGDD, ¿a qué edad es válido el consentimiento de un menor de edad para el tratamiento de datos referentes a su raza?
- a) A partir de los 13 años
 - b) A partir de los 14 años
 - c) A partir de los 16 años
 - d) En ningún caso es válido el consentimiento
- 27) ¿En qué caso un organismo público puede verificar en el INE la dirección proporcionada por un ciudadano que ha iniciado un procedimiento de su competencia?
- a) Con consentimiento del interesado
 - b) Siempre que no haya manifestado su oposición
 - c) Solo si se trata de un procedimiento de inspección o sancionador
 - d) En todo caso
- 28) ¿Puede un organismo recabar documentos elaborados por otros órganos de la Administración que sean necesarios para el procedimiento administrativo en caso de que no hayan sido aportados por el interesado?
- a) Con consentimiento del interesado

- b) Siempre que no haya manifestado su oposición
 - c) Siempre que se trate de un procedimiento de inspección o sancionador
 - d) Las dos anteriores son ciertas
- 29) ¿Cuál es la sanción correspondiente para una administración pública que sistemáticamente ignore las solicitudes para el ejercicio de los derechos de los afectados y los requerimientos de la AEPD al respecto?
- a) Multa de hasta 2 millones de euros
 - b) Multa de hasta 4 millones de euros
 - c) Apercibimiento, y en su caso propuesta de medidas disciplinarias
 - d) Depende de otros condicionantes que no da el enunciado de la pregunta
- 30) ¿Cuál de las siguientes afirmaciones es cierta respecto a la AEPD?
- a) Es una autoridad administrativa independiente de ámbito autonómico
 - b) Depende del Ministerio de Justicia
 - c) Actúa únicamente con capacidad pública
 - d) Todas son falsas

10.2 SOLUCIONES A LAS PREGUNTAS DE TEST

PREGUNTA	SOLUCIÓN
1	c
2	a
3	d
4	b
5	a
6	c
7	c
8	d
9	c
10	c
11	d
12	d
13	b
14	b
15	d
16	a
17	a
18	d
19	d
20	a
21	b
22	c
23	a
24	b
25	d
26	d
27	d
28	d
29	c
30	d

11 BIBLIOGRAFÍA BÁSICA

11.1 BIBLIOGRAFÍA BÁSICA

1. Reglamento (UE) 2016/679, General de Protección de Datos, <https://www.boe.es/doue/2016/119/L00001-00088.pdf>
2. Ley Orgánica 3/2018, de Protección de Datos Personales y garantía de los derechos digitales, <https://boe.es/boe/dias/2018/12/06/pdfs/BOE-A-2018-16673.pdf>

11.2 BIBLIOGRAFÍA PARA AMPLIAR EL TEMA

3. Ley 34/2002, de servicios de la sociedad de la información y de comercio electrónico, <https://www.boe.es/buscar/act.php?id=BOE-A-2002-13758>
4. Ley 9/2014, General de Telecomunicaciones, <https://www.boe.es/buscar/act.php?id=BOE-A-2014-4950>
5. Directiva (UE) 2016/680, relativo a los tratamientos para fines de prevención, investigación, detección o enjuiciamiento de infracciones penales o de ejecución de sanciones penales, <https://www.boe.es/doue/2016/119/L00089-00131.pdf>
6. Reglamento (UE) 2018/1725, relativo a los tratamientos por las instituciones de la UE, <https://www.boe.es/doue/2018/295/L00039-00098.pdf>
7. Circular de la AEPD respecto al tratamiento de opiniones políticas por partidos, https://boe.es/diario_boe/txt.php?id=BOE-A-2019-3423
8. Guías de la AEPD, <https://www.aepd.es/guias/index.html>
9. Informes jurídicos de la AEPD, <https://www.aepd.es/informes/juridicos/>
10. Guías de actuación del grupo de trabajo del artículo 29 (en inglés en su mayoría), https://ec.europa.eu/newsroom/article29/news.cfm?item_type=1360